



Universidad Internacional de La Rioja
Escuela Superior de Ingeniería y Tecnología

Máster Universitario en Ciberseguridad

Metodología ligera de auditoría TLS 1.3 en entornos corporativos

Trabajo fin de estudio presentado por:	José Francisco Vega Díaz
Tipo de trabajo:	Metodología
Director/a:	José Ramón Coz Fernández
Fecha:	22/06/2026

Resumen

La seguridad de las comunicaciones en Internet depende de un protocolo llamado TLS (Transport Layer Security), que cifra la información que viaja entre un navegador y un servidor web. Disponer del candado en el navegador no garantiza que la configuración sea segura: muchas organizaciones mantienen activas versiones antiguas del protocolo con vulnerabilidades conocidas sin saberlo, especialmente las pequeñas y medianas empresas que carecen de personal especializado.

Este trabajo diseña y valida una metodología ligera de auditoría que permite a cualquier administrador de sistemas evaluar el estado real de la configuración TLS de su servidor web y migrarlo a TLS 1.3, la versión más segura del protocolo, usando exclusivamente herramientas gratuitas. La metodología se estructura en cuatro fases: planificación, recogida de información, análisis y diagnóstico, y elaboración de informe.

Su aplicabilidad se valida sobre una empresa ficticia denominada SecureNet Solutions S.L., diseñada para representar las características habituales de las pequeñas y medianas empresas (PYMEs). Antes de aplicar la metodología, el servidor presentaba configuraciones inseguras y obtuvo una calificación B en la auditoría. Tras la aplicación de las mejoras propuestas, alcanzó la calificación de A, reflejando una configuración alineada a las buenas prácticas y estándares internacionales de seguridad. Además, se plantean futuras líneas de trabajo orientadas a complementar la metodología desarrollada y explorar su aplicación en otros entornos y escenarios de uso.

Palabras clave: TLS 1.3, auditoría de seguridad, metodología ligera, servidor web, ciberseguridad corporativa.

Abstract

Internet security relies on a protocol called TLS (Transport Layer Security), which encrypts information traveling between a browser and a web server. Having a padlock icon in the browser does not guarantee a secure configuration: many organizations unknowingly run outdated protocol versions with known vulnerabilities, particularly small and medium-sized enterprises lacking dedicated security staff.

This work designs and validates a lightweight audit methodology that allows any systems administrator to assess the real state of their web server's TLS configuration and migrate it to TLS 1.3, the most secure version of the protocol, using only free tools. The methodology is structured in four phases: planning, information gathering, analysis and diagnosis, and report writing.

Its applicability is validated on a fictitious company called SecureNet Solutions S.L., designed to represent the typical characteristics of small and medium-sized enterprises (SMEs). Before applying the methodology, the server presented insecure configurations and received a B rating in the audit. After applying the proposed improvements, it achieved an A rating, reflecting a configuration aligned with international security best practices and standards. Additionally, future lines of work are identified to complement the methodology developed and explore its application in other environments and use cases.

Keywords: TLS 1.3, security audit, lightweight methodology, web server, corporate cybersecurity.

Índice de contenidos

1.	Introducción.....	1
1.1.	Motivación.....	1
1.2.	Planteamiento del problema.....	3
1.3.	Estructura del trabajo.....	3
2.	Estado del arte.....	5
2.1.	Evolución de los protocolos SSL/TLS.....	7
2.2.	TLS 1.3: novedades y mejoras.....	9
2.3.	Vulnerabilidades en versiones anteriores.....	12
2.3.1.	SSL 3.0 y POODLE.....	12
2.3.2.	TLS 1.0 y BEAST.....	12
2.3.3.	TLS 1.0, 1.1, 1.2 y CRIME.....	12
2.3.4.	Heartbleed (OpenSSL).....	13
2.3.5.	Ataques de downgrade.....	13
2.3.6.	Deprecación formal de TLS 1.0 y 1.1.....	13
2.4.	Estándares y buenas prácticas de configuración.....	14
2.4.1.	OWASP ASVS.....	14
2.4.2.	NIST SP 800-52.....	15
2.4.3.	ISO 27001 A.10.....	15
2.4.4.	Buenas prácticas adicionales.....	15
2.5.	Herramientas para auditoría TLS.....	16
2.5.1.	SSL Labs (Qualys SSL Server Test).....	17
2.5.2.	testssl.sh.....	17
2.5.3.	Otras herramientas.....	18
2.5.4.	Selección para la metodología propuesta.....	19

3.	Objetivos concretos y metodología de trabajo.....	20
3.1.	Objetivo general	20
3.2.	Objetivos específicos	20
3.3.	Metodología del trabajo	21
3.3.1.	Fase 1: Planificación	22
3.3.2.	Fase 2: Recogida de información.....	23
3.3.3.	Fase 3: Análisis y diagnóstico	24
3.3.4.	Fase 4: Informe y recomendaciones.....	25
4.	Desarrollo de la propuesta.....	27
4.1.	Identificación de requisitos	27
4.1.1.	Requisitos técnicos	27
4.1.2.	Requisitos organizativos.....	28
4.1.3.	Requisitos de conocimiento	29
4.1.4.	Roles y responsabilidades	29
4.2.	Diseño de la propuesta	30
4.2.1.	Evaluación de herramientas	30
4.2.2.	Arquitectura de la propuesta del sistema	33
4.2.3.	Análisis funcional.....	35
4.3.	Aplicación al caso de uso SecureNet Solution SL.....	37
4.3.1.	Descripción del entorno simulado,.....	38
4.3.2.	Alcance de la auditoría	39
4.3.3.	Configuración inicial (TLS 1.2)	42
4.3.4.	Ejecución de pruebas pre-migración	43
4.3.5.	Procedimiento de migración a TLS 1.3	46
4.3.6.	Ejecución de pruebas post-migración	50

4.4.	Resultados	56
4.4.1.	Resultados obtenidos antes de la migración.....	56
4.4.2.	Resultados obtenidos después de la migración	57
4.4.3.	Comparativa y análisis.....	59
4.4.4.	Discusión de hallazgos.....	62
5.	Conclusiones y trabajo futuro.....	66
5.1.	Conclusiones.....	66
5.2.	Limitaciones del estudio	68
5.3.	Trabajos futuros.....	69
	Referencias bibliográficas	73

Índice de figuras

Figura 1 Comparativa del handshake TLS 1.2 frente a TLS 1.3	9
Figura 2 Arquitectura del sistema de auditoría TLS propuesto	35
Figura 3 Diagrama de infraestructura de SecureNet Solutions S.L.....	39
Figura 4 Calificación SSL Labs pre-migración: B.....	44
Figura 5 Salida de testssl.sh pre-migración: versiones y cifrados detectados.....	45
Figura 6 Flujo del procedimiento de migración a TLS 1.3.....	50
Figura 7 Calificación SSL Labs post-migración: A.....	51
Figura 8 Salida de testssl.sh post-migración: versiones y cifrados verificados	53

Índice de tablas

Tabla 1 Hitos en la evolución de SSL/TLS	9
Tabla 2 Principales vulnerabilidades en versiones anteriores de SSL/TLS	14
Tabla 3 Resumen de requisitos de estándares para configuración TLS	16
Tabla 4 Comparativa de herramientas para auditoría TLS	18
Tabla 5 Evaluación comparativa de herramientas candidatas	32
Tabla 6 Bloques funcionales, criterios de evaluación y herramientas de verificación	37
Tabla 7 Resumen del alcance de la auditoría	41
Tabla 8 Hallazgos de la auditoría pre-migración clasificados por severidad	46
Tabla 9 Comparativa de resultados pre y post-migración por bloque funcional	54

1. Introducción

El protocolo Transport Layer Security (TLS) constituye el estándar predominante para asegurar las comunicaciones en Internet, proporcionando confidencialidad, integridad y autenticación entre clientes y servidores (Rescorla, 2018). En agosto de 2018, el Internet Engineering Task Force (IETF) publicó la versión TLS 1.3 mediante el RFC 8446, suponiendo la revisión más significativa del protocolo en casi una década (Rescorla, 2018).

Esta nueva versión incorpora mejoras sustanciales. Elimina algoritmos criptográficos obsoletos como SHA-1, RC4 y 3DES. Reduce la latencia del handshake de dos a un viaje de ida y vuelta, e incluso permite 0-RTT para conexiones reanudadas. Obliga al uso de Perfect Forward Secrecy (PFS), garantizando que la compromisión de claves a largo plazo no afecte a sesiones anteriores (Dowling et al., 2021).

Pese a ello, la progresión de TLS 1.3 en el ámbito corporativo, sobre todo en el contexto de las empresas grandes, pequeñas y medianas, es insuficiente. De acuerdo a la telemetría recogida por Mozilla Firefox, en el 2021 ya era del 66,4% la actividad de conexiones que empleaban TLS 1.3, lo que significa que un porcentaje elevado aún opera con versiones previas (Tecnologías habilitadoras, s.f.).

Las causas de esta lentitud son diversas: falta de metodologías ajustadas a los recursos limitados, miedo a que aplicaciones legadas dejen de cumplir sus funciones, desconocimiento técnico sobre cómo auditar la configuración existente, falta de guías prácticas que no requieran personal especializado o bi-lin-gües, etc.

1.1. Motivación

La adopción del protocolo TLS 1.3 en las organizaciones que se mueven en un entorno PYMEs presenta una brecha notablemente importante entre la capacidad que hace y la que realmente se utiliza. Por ejemplo, la telemetría que obtiene Mozilla Firefox muestra que, en 2021, alrededor del 66,4% de las conexiones web ya empleaban TLS 1.3, por tanto, un tercio (aproximadamente una de cada tres conexiones) aún lo hacía con versiones previas (Tecnologías habilitadoras, s.f.).

El problema que se detecta hay la falta de metodologías ligeras, documentadas y validadas para auditar TLS 1.3 en servidores web de PYMEs. Las grandes organizaciones cuentan con

departamentos de seguridad, herramientas comerciales y especialistas de dedicación plena. Las organizaciones de menor tamaño carecen de estas condiciones y, por lo tanto, son víctimas de una exposición a riesgos evitables.

Las causas de esta situación son múltiples. En primer lugar, existe un desconocimiento de cuál es el estado real de la configuración TLS en los servidores de las propias organizaciones. Muchos administradores asumen que, si se tiene un certificado digital, la comunicación está completamente asegurada sin verificar cuál es la versión del protocolo o cuáles son los cifrados habilitados (Qualys SSL Labs, 2021). En segundo lugar, hay un miedo a que la migración rompa la compatibilidad con clientes o aplicaciones antiguas que todavía no soporten. En tercer lugar, la documentación disponible suele ser excesivamente técnica o, por el contrario, demasiado genérica, sin ofrecer pasos concretos y reproducibles.

La relevancia del problema se fundamenta en tres aspectos.

1. La seguridad: Las versiones TLS 1.0 y 1.1 han sido formalmente deprecadas por el IETF en 2021 (RFC 8996), y numerosas vulnerabilidades han sido documentadas y explotadas en estos protocolos, incluyendo POODLE (2014), Heartbleed (2014) y diversos ataques de downgrade (Snapshot, s.f.). TLS 1.2, aunque todavía aceptable, permite configuraciones inseguras si no se aplican rigurosamente las buenas prácticas.
2. El rendimiento: TLS 1.3 reduce la latencia del handshake de dos a un viaje de ida y vuelta, e incluso permite 0-RTT para conexiones reanudadas (Rescorla, 2018). Esta mejora impacta directamente en la experiencia del usuario y en el posicionamiento en buscadores, factores críticos para cualquier organización con presencia web.
3. El cumplimiento normativo: Estándares como OWASP ASVS (versión 4.0.2) y la norma ISO 27001, en su apartado A.10 sobre controles criptográficos, recomiendan explícitamente el uso de TLS 1.3 y la deshabilitación de versiones anteriores. Las organizaciones que no migran pueden incurrir en incumplimientos durante auditorías de certificación.

Por todo ello, resulta pertinente disponer de una guía estructurada, de bajo costo y fácilmente replicable, que permita a una organización con conocimientos técnicos básicos auditar su estado actual y ejecutar una migración controlada hacia TLS 1.3.

1.2. Planteamiento del problema

La falta de una metodología estructurada y accesible para auditar la configuración de TLS en servidores web constituye una barrera significativa para la adopción de TLS 1.3 en PYMEs. Las organizaciones de este tamaño suelen carecer de personal de seguridad dedicado y de presupuesto para herramientas comerciales de análisis. Como resultado, muchas continúan utilizando versiones obsoletas del protocolo (TLS 1.0, 1.1 o configuraciones inseguras de TLS 1.2) sin conocer el estado real de sus comunicaciones cifradas.

La propuesta se ha centrado en elaborar una metodología de auditoría ligera estructurada en cuatro fases sucesivas que se denominan: planificación, recogida de información de la configuración TLS, análisis y diagnóstico de la información obtenida, y la elaboración de un informe de auditoría. Todas estas fases se agradecen en exclusiva en herramientas libres y ampliamente documentadas y funcionales como pueden ser SSL Labs y testssl.sh, de manera que no se precisa realizar ninguna inversión en software propietario.

Por un lado, se proporciona a los administradores de los sistemas con conocimientos técnicos básicos una guía simple y reproducible sobre cómo evaluar la configuración TLS de sus servidores web. Por otro lado, se demuestra con un caso de estudio simulado que la metodología es viable y que la migración de TLS 1.2 a TLS 1.3 aporta mejoras objetivas y medibles en la nota de seguridad.

La finalidad última de todo ello se pueda cerrar la brecha existente entre las capacidades que ofrece el TLS 1.3 y su implementación real en el tejido empresarial de menor tamaño de modo que se ayude a elevar el nivel de seguridad general de las comunicaciones en Internet.

1.3. Estructura del trabajo

El presente apartado ha establecido el problema de estudio, las causas que lo originan y la relevancia de abordarlo mediante una metodología ligera de auditoría TLS 1.3. A continuación, se describe la organización del resto del documento, indicando el contenido principal de cada una de las secciones que lo componen.

Estado del arte. Esta sección revisa los fundamentos teóricos y técnicos necesarios para comprender el contexto del estudio. Se aborda la evolución histórica de los protocolos SSL y TLS, desde sus orígenes hasta la versión actual. Se analizan en detalle las novedades

introducidas por TLS 1.3, incluyendo la reducción de latencia, la eliminación de algoritmos obsoletos y la obligatoriedad de Perfect Forward Secrecy. Se examinan las vulnerabilidades más significativas documentadas en versiones anteriores, como POODLE, Heartbleed y los ataques de downgrade. Se revisan los estándares y buenas prácticas de configuración TLS, con especial atención a OWASP ASVS, NIST SP 800-52 e ISO 27001 A.10. Por último, se describen las herramientas gratuitas disponibles para auditoría TLS, entre las que destacan SSL Labs y testssl.sh.

Objetivos y metodología. Esta sección define el propósito del estudio y el camino para alcanzarlo. Se formula el objetivo general que guía todo el desarrollo. Se enumeran los objetivos específicos que permiten descomponer el objetivo general en metas alcanzables. Se presenta la metodología de trabajo estructurada en cuatro fases secuenciales: planificación, recogida de información, análisis y diagnóstico, e informe y recomendaciones, describiendo en detalle los pasos, herramientas y criterios de evaluación de cada una.

Desarrollo de la propuesta. Esta sección constituye el núcleo del trabajo y se organiza en cuatro apartados. En primer lugar, se identifican los requisitos previos necesarios para aplicar la metodología, tanto técnicos como organizativos. En segundo lugar, se presenta el diseño de la propuesta, que incluye la planificación y alcance, la evaluación de herramientas gratuitas disponibles, la arquitectura del sistema propuesto y el análisis funcional de las funcionalidades a verificar. En tercer lugar, se aplica la propuesta al caso de uso de SecureNet Solutions S.L., una PYME tecnológica ficticia, documentando la descripción del entorno simulado, el alcance de la auditoría, la configuración inicial, la ejecución de pruebas pre-migración, el procedimiento de migración a TLS 1.3 y las pruebas post-migración. En cuarto lugar, se presentan los resultados obtenidos, incluyendo la comparativa antes y después de la migración y la discusión de los hallazgos más relevantes.

Conclusiones y trabajos futuros. Esta sección cierra el documento en dos partes. La primera recoge las conclusiones del trabajo, con un resumen amplio de lo realizado y una valoración del grado de cumplimiento de cada objetivo específico planteado. La segunda identifica líneas de trabajo futuro que podrían dar continuidad a la propuesta desarrollada, ampliando su alcance a otros entornos, protocolos o niveles de automatización.

Referencias bibliográficas. Se incluye el listado completo de todas las fuentes citadas a lo largo del documento, formateado según la normativa APA.

2. Estado del arte

El protocolo TLS 1.3 representa la evolución más significativa en la seguridad de las comunicaciones en Internet desde la publicación de TLS 1.2 en 2008 (Rescorla, 2018; IETF, 2008). Para comprender el alcance de esta nueva versión y fundamentar la metodología de auditoría propuesta, resulta necesario examinar los antecedentes históricos, las innovaciones técnicas, las vulnerabilidades que motivaron el cambio, los estándares que regulan su configuración y las herramientas disponibles para su evaluación (Dowling et al., 2021; Sullivan, 2018).

La historia de los protocolos de cifrado para transporte de datos se remonta a la década de 1990, cuando Netscape desarrolló SSL (Secure Sockets Layer) para proteger las transacciones comerciales en la incipiente web comercial (Paulson, 1999). La versión SSL 2.0, lanzada en 1995, contenía múltiples fallos de seguridad que llevaron a su rápida sustitución por SSL 3.0 en 1996. A partir de 1999, el IETF (Internet Engineering Task Force) asumió el estándar bajo la denominación TLS (Transport Layer Security), publicando TLS 1.0 como RFC 2246 (IETF, 1999).

Le siguieron TLS 1.1 en 2006 (IETF, 2006) y TLS 1.2 en 2008 (IETF, 2008), versión que ha predominado durante más de una década (Kotzias et al., 2018). Cada una de estas versiones introdujo mejoras incrementales: TLS 1.1 añadió protección contra ataques de cifrado en bloque CBC; TLS 1.2 incorporó los algoritmos de hash SHA-2 y eliminó la dependencia de MD5 (Rescorla, 2001).

TLS 1.3, publicado en agosto de 2018 como RFC 8446 (Rescorla, 2018), supone un cambio cualitativo respecto a sus predecesores. La principal novedad es la reducción del handshake de dos viajes de ida y vuelta (2-RTT) a uno solo (1-RTT) (Langley et al., 2016). Para conexiones reanudadas, permite incluso 0-RTT, lo que mejora sustancialmente la latencia percibida por el usuario (Cloudflare, 2018). Esta optimización se logra eliminando pasos de negociación inseguros y asumiendo por defecto las opciones más robustas (Beurdouche et al., 2015).

Otra innovación fundamental es la obligatoriedad del Perfect Forward Secrecy (PFS) (Adrian et al., 2015). Esta propiedad garantiza que la compromisión de la clave privada a largo plazo del servidor no permita descifrar sesiones anteriores capturadas.

TLS 1.3 también elimina algoritmos criptográficos obsoletos o vulnerables: RC4, DES, 3DES, AES-CBC, MD5, SHA-1 y los intercambios de clave RSA y Diffie-Hellman estáticos (Bhargavan

& Leurent, 2016). En su lugar, admite exclusivamente cinco suites de cifrado autenticadas con datos asociados (AEAD): TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256, TLS_AES_128_CCM_SHA256 y TLS_AES_128_CCM_8_SHA256 (Dowling et al., 2021).

Las versiones anteriores del protocolo acumulan un historial extenso de vulnerabilidades explotables. SSL 3.0 fue víctima del ataque POODLE (2014) (Möller et al., 2014), que permitía descifrar cookies de sesión mediante ataques de relleno. TLS 1.0 y 1.1 sufrieron los ataques BEAST (2011) y CRIME (2012) (Azás, 2018), que explotaban la compresión y el cifrado CBC (AlFardan & Paterson, 2013). La vulnerabilidad Heartbleed (2014) no afectó al protocolo en sí, sino a una implementación concreta de OpenSSL, pero evidenció la fragilidad del ecosistema (Durumeric et al., 2014).

TLS 1.2, aunque más robusto, permite configuraciones inseguras si no se aplican rigurosamente las buenas prácticas (Lee et al., 2017). La habilitación de cifrados débiles, la aceptación de compresión o la negociación de versiones anteriores mediante ataques de downgrade siguen siendo riesgos latentes (Adrian et al., 2015). El IETF formalizó la deprecación de TLS 1.0 y 1.1 en marzo de 2021 mediante el RFC 8996 (IETF, 2021), recomendando su deshabilitación completa en todos los servidores (Felt et al., 2017).

La configuración segura de TLS no depende únicamente de la versión del protocolo, sino de la correcta aplicación de estándares reconocidos (NIST, 2019). OWASP (Open Web Application Security Project) publica periódicamente su ASVS (Application Security Verification Standard) (OWASP, 2019). La versión 4.0.2 dedica el apartado V9 a los requisitos de comunicaciones seguras. Este estándar permite únicamente TLS 1.2 o superior, debe tener deshabilitados SSL y TLS 1.0/1.1, debe tener configuraciones de cifrados fuertes en el preferido adecuado y debe reexaminarse periódicamente mediante herramientas de análisis (OWASP, 2023).

El NIST (National Institute of Standards and Technology) edita la guía SP 800-52, donde se definen directrices para la selección y configuración de TLS en Estados Unidos (NIST, 2019). La norma ISO 27001, en su anexo A.10 de controles criptográficos, recoge que existen políticas de uso de cifrado donde se pretenden la gestión de claves y la selección de algoritmos robustos (ISO/IEC, 2022). Conforme a la norma también el control A.10.1.1 debe tener certificados SSL/TLS que tengan una validez máxima de 2 años y una longitud mínima de 2048

bits mientras que las conexiones SSL deben tener habilitadas las conexiones SSL en favor de TLS v.1.3 (ENISA, 2021).

La auditoría TLS requiere herramientas específicas que permitan evaluar la configuración real de un servidor desde la perspectiva de un cliente externo (Qualys SSL Labs, 2021). SSL Labs, desarrollado por Qualys, es la herramienta de referencia en el sector. Ofrece un análisis gratuito basado en navegador que asigna una calificación de la A a la F, identifica las versiones de TLS habilitadas y lista los cifrados soportados en orden de preferencia (Durumeric et al., 2013). También detecta vulnerabilidades conocidas (Heartbleed, POODLE, FREAK, Logjam, DROWN) y simula el handshake con diferentes navegadores y sistemas operativos.

testssl.sh es una alternativa de línea de comandos, de código abierto y ejecutable localmente (testssl.sh, 2023). Permite auditar servidores sin depender de servicios externos. Ambas herramientas son ampliamente utilizadas por administradores de sistemas, auditores de seguridad e investigadores (Lyon, 2009). Constituyen la base técnica sobre la que se apoya la metodología propuesta.

El estado del arte revela que TLS 1.3 ofrece ventajas indiscutibles en seguridad y rendimiento respecto a versiones anteriores (Rescorla, 2018; Dowling et al., 2021). Los estándares internacionales recomiendan explícitamente su adopción (OWASP, 2019; NIST, 2019; ISO/IEC, 2022). Existen herramientas gratuitas y maduras para auditar su correcta implementación (Qualys SSL Labs, 2021; testssl.sh, 2023). Sin embargo, persiste una brecha entre estas capacidades técnicas y su aplicación real en PYMEs (Kotzias et al., 2018; Lee et al., 2017). La metodología propuesta pretende reducir esa brecha (Sullivan, 2018). Los conceptos y herramientas aquí revisados constituyen la base sobre la que se construyen los objetivos, el diseño metodológico y el caso de estudio que se presentan en las secciones siguientes.

2.1. Evolución de los protocolos SSL/TLS

El desarrollo de los protocolos de cifrado para comunicaciones en red responde a la necesidad de proteger los datos transmitidos entre clientes y servidores ante un creciente número de amenazas (Rescorla, 2001). Esta evolución abarca desde los primeros diseños de Netscape hasta la estandarización actual a cargo del IETF (Paulson, 1999).

A mediados de la década de 1990, Netscape Communications identificó la necesidad de proteger las transacciones comerciales que comenzaban a realizarse a través de la World Wide

Web (Freier et al., 1996). La respuesta fue Secure Sockets Layer (SSL), un protocolo que operaba entre la capa de transporte y la capa de aplicación. La primera versión pública de SSL fue la 2.0, lanzada en 1995, que contenía muchos fallos de seguridad, como la no verificación de la integridad del handshake, el uso de claves débiles para el cifrado y las vulnerabilidades del ataque de truncamiento (Wagner y Schneier, 1996).

En 1996 fue publicada la versión SSL 3.0, una revisión completa que corregía los errores más graves de la versión anterior con una nueva versión que incorporó el registro fragmentado, el soporte para alertas y un mecanismo de handshake mejorado (Freier et al., 1996). A pesar de estos cambios, las vulnerabilidades fueron aumentando, como el ataque POODLE de 2014, que aprovechaba el relleno CBC (Möller et al., 2014). El paso clave hacia un estándar abierto fue en 1999, cuando el IETF se hizo cargo del protocolo bajo el nombre de Transport Layer Security (TLS) (Dierks y Allen, 1999).

La primera versión de TLS, TLS 1.0 (RFC 2246), fue esencialmente SSL 3.0 pero con ligeros cambios y un lenguaje más claro especificado en (IETF, 1999). Aunque se consideró un avance, la ruta continuó con la evidencia de que la versión era vulnerable a ataques como BEAST (2011), que explotaba la ruptura del cifrado CBC (Duong y Rizzo, 2011).

TLS 1.1 (RFC 4346) fue finalmente lanzado en 2006 y esta versión era una mejora incremental (IETF, 2006). Incorporó protección explícita contra ataques de cifrado en bloque CBC mediante el uso de vectores de inicialización aleatorios. También añadió mecanismos para evitar la fragmentación maliciosa de mensajes. A pesar de estas correcciones, la adopción de TLS 1.1 fue limitada, ya que muchos desarrolladores optaron por esperar a la siguiente versión (Kotzias et al., 2018).

TLS 1.2 (RFC 5246), publicado en 2008, se convirtió en el estándar dominante durante más de una década (IETF, 2008). Introdujo los algoritmos de hash SHA-2, eliminó la dependencia de MD5 y permitió especificar el algoritmo de hash utilizado en la firma digital del handshake. También añadió soporte para modos de cifrado autenticado (GCM, CCM) (Dierks & Rescorla, 2008). Sin embargo, TLS 1.2 mantenía cierta flexibilidad que permitía configuraciones inseguras si no se aplicaban rigurosamente las buenas prácticas (Lee et al., 2017).

En agosto de 2018, tras cinco años de desarrollo y 28 borradores, el IETF publicó TLS 1.3 como RFC 8446 (Rescorla, 2018). Esta versión supuso un cambio cualitativo, no meramente

incremental. Eliminó todos los algoritmos considerados débiles, redujo la latencia del handshake e hizo obligatorio el Perfect Forward Secrecy (Dowling et al., 2021). La tabla 1 resume los hitos más relevantes de esta evolución.

Tabla 1 Hitos en la evolución de SSL/TLS

Año	Versión	Documento	Principales novedades
1995	SSL 2.0	Propietario	Primera implementación pública (insegura)
1996	SSL 3.0	Propietario	Corrección de fallos de SSL 2.0
1999	TLS 1.0	RFC 2246	Estandarización IETF, base SSL 3.0
2006	TLS 1.1	RFC 4346	Protección contra ataques CBC
2008	TLS 1.2	RFC 5246	SHA-2, eliminación de MD5, cifrado autenticado
2018	TLS 1.3	RFC 8446	Handshake 1-RTT, PFS obligatorio, eliminación de algoritmos débiles

Fuente: elaboración propia.

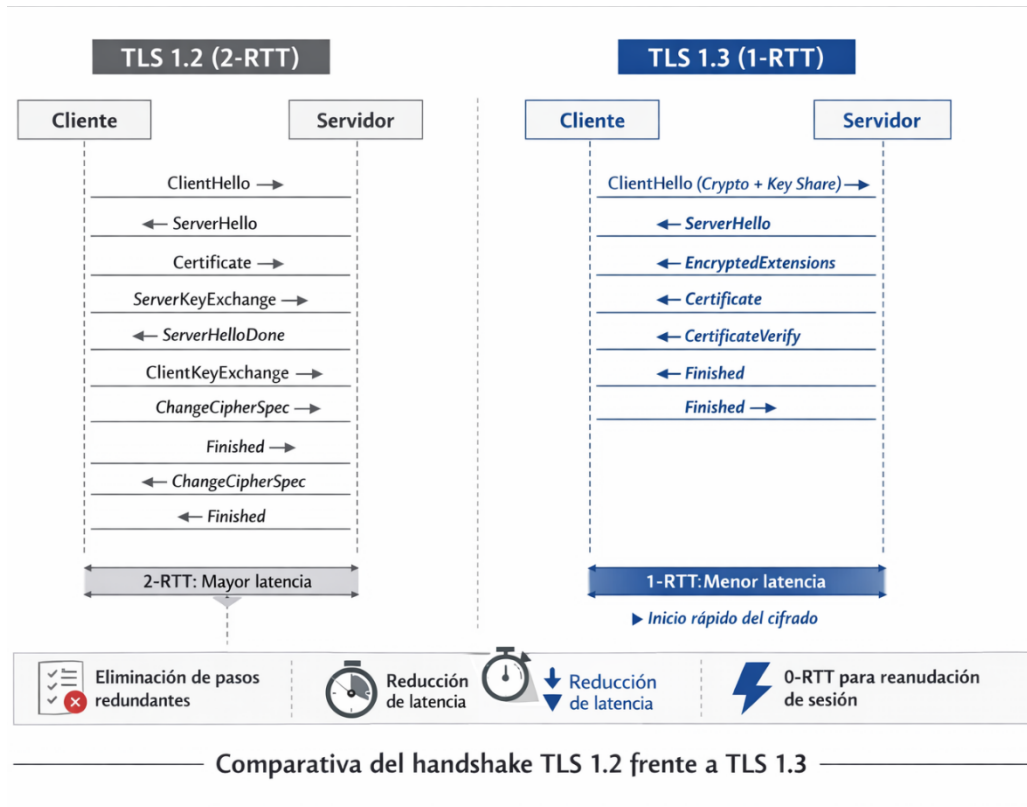
2.2. TLS 1.3: novedades y mejoras

TLS 1.3, publicado en agosto de 2018 como RFC 8446 (Rescorla, 2018), introduce cambios sustanciales respecto a TLS 1.2. Estas modificaciones afectan tanto al rendimiento como a la seguridad del protocolo (Dowling et al., 2021). A continuación, se describen las más relevantes.

La mejora más visible es la reducción de la latencia en el establecimiento de la conexión. En TLS 1.2, el handshake completo requería dos viajes de ida y vuelta (2-RTT) entre el cliente y el servidor antes de poder enviar datos cifrados (Dierks & Rescorla, 2008). TLS 1.3 reduce este proceso a un solo viaje (1-RTT) para conexiones nuevas (Rescorla, 2018).

Para conexiones ya establecidas que se reanudan, permite incluso cero viajes (0-RTT), enviando datos cifrados en el primer mensaje (Cloudflare, 2018). Esta optimización se logra eliminando pasos redundantes y asumiendo por defecto las opciones criptográficas más seguras (Langley et al., 2016).

Figura 1 Comparativa del handshake TLS 1.2 frente a TLS 1.3



Fuente: elaboración propia.

La figura muestra el intercambio de mensajes entre cliente y servidor en TLS 1.2 (2-RTT) y TLS 1.3 (1-RTT), destacando la reducción de viajes de ida y vuelta en la versión más reciente.

Otra innovación fundamental es la obligatoriedad del Perfect Forward Secrecy (PFS) (Adrian et al., 2015). Esta propiedad criptográfica garantiza que la compromisión de la clave privada a largo plazo del servidor no permita descifrar sesiones anteriores que hayan sido capturadas (Diffie & Hellman, 1976). En TLS 1.2, el PFS era opcional y dependía de la correcta configuración del servidor. En TLS 1.3, todos los modos de intercambio de clave lo incorporan por defecto, eliminando la posibilidad de configuraciones inseguras (Rescorla, 2018).

TLS 1.3 también simplifica drásticamente el conjunto de algoritmos soportados. Elimina todos aquellos considerados débiles o vulnerables: RC4, DES, 3DES, AES-CBC, MD5, SHA-1 y los intercambios de clave RSA y Diffie-Hellman estáticos (Bhargavan & Leurent, 2016). En su lugar, admite exclusivamente cinco suites de cifrado, todas ellas basadas en el modo de cifrado autenticado con datos asociados (AEAD):

- TLS_AES_128_GCM_SHA256
- TLS_AES_256_GCM_SHA384

- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_CCM_SHA256
- TLS_AES_128_CCM_8_SHA256

Esta simplificación tiene dos efectos positivos. Por un lado, reduce la superficie de ataque al eliminar opciones inseguras (Beurdouche et al., 2015). Por otro lado, facilita la auditoría, ya que el auditor solo debe verificar la presencia de estas cinco suites y la ausencia de cualquier otra (Sullivan, 2018).

En cuanto a la seguridad del handshake, TLS 1.3 cifra una porción mayor de los mensajes intercambiados. Mientras que TLS 1.2 transmitía en claro los certificados y algunos parámetros de negociación, TLS 1.3 cifra todo el handshake después del mensaje ServerHello (Rescorla, 2018). Esto impide que un atacante pasivo pueda inspeccionar los certificados o deducir información sobre los parámetros negociados (Beurdouche et al., 2015).

Además, TLS 1.3 incorpora protección explícita contra ataques de downgrade (Sullivan, 2018). En versiones anteriores, un atacante en posición de intermediario podía forzar la negociación de una versión más débil del protocolo (Adrian et al., 2015). TLS 1.3 incluye mecanismos criptográficos que hacen detectable cualquier intento de downgrade, rechazando la conexión si se produce (Rescorla, 2018).

Por último, el nuevo protocolo elimina funcionalidades problemáticas que rara vez se utilizaban correctamente. Entre ellas se encuentran la renegociación de parámetros durante una conexión activa, la compresión de mensajes (vulnerable al ataque CRIME) y el intercambio de claves RSA estático (sin PFS) (Bhargavan & Leurent, 2016; AlFardan & Paterson, 2013).

En conjunto, estas novedades hacen de TLS 1.3 un protocolo más seguro, más rápido y más fácil de auditar que sus predecesores (Dowling et al., 2021). La reducción del handshake mejora la experiencia del usuario (Langley et al., 2016). La eliminación de algoritmos débiles reduce el riesgo de error de configuración (Beurdouche et al., 2015). La obligatoriedad del PFS protege sesiones pasadas incluso si las claves a largo plazo se ven comprometidas (Adrian et al., 2015). Estos atributos justifican la pertinencia de una metodología específica para auditar su correcta implantación en entornos corporativos (Sullivan, 2018).

2.3. Vulnerabilidades en versiones anteriores

Las versiones de SSL y TLS anteriores a 1.3 acumulan un historial extenso de vulnerabilidades explotables. Algunas afectan al diseño del protocolo. Otras se deben a implementaciones defectuosas. En conjunto, justifican la necesidad de migrar a TLS 1.3.

2.3.1. SSL 3.0 y POODLE

En 2014 se descubrió el ataque POODLE (Padding Oracle On Downgraded Legacy Encryption) por parte de tres investigadores de seguridad de Google: Bodo Möller, Thai Duong y Krzysztof Kotowicz (Möller et al., 2014). Este ataque afectaba a SSL 3.0 y permitía descifrar cookies de sesión mediante ataques de relleno CBC. Un atacante en posición de intermediario podía forzar la negociación de SSL 3.0 incluso cuando cliente y servidor soportaban versiones superiores. La única solución completa fue deshabilitar SSL 3.0 en todos los servidores.

2.3.2. TLS 1.0 y BEAST

En 2011 se publicó el ataque BEAST (Browser Exploit Against SSL/TLS) por Thai Duong y Juliano Rizzo (Duong & Rizzo, 2011). Afectaba a TLS 1.0 y explotaba una debilidad en el modo CBC del cifrado de bloque, específicamente el uso del último bloque de cifrado anterior como vector de inicialización (IV) predecible. Un atacante podía descifrar gradualmente las cookies de sesión inyectando fragmentos en la comunicación (Bard, 2006). Los navegadores implementaron mitigaciones del lado del cliente, pero la vulnerabilidad evidenció las limitaciones de TLS 1.0.

2.3.3. TLS 1.0, 1.1, 1.2 y CRIME

En 2012 apareció el ataque CRIME (Compression Ratio Info-leak Made Easy), presentado por Juliano Rizzo y Thai Duong en la conferencia Ekoparty (Rizzo & Duong, 2012). Este ataque explotaba la compresión de mensajes en TLS. Un atacante podía recuperar el contenido de las cookies observando las variaciones en la longitud de los mensajes comprimidos (Be'ery & Shulman, 2013). La solución fue deshabilitar la compresión a nivel de TLS, funcionalidad que TLS 1.3 eliminó por completo.

2.3.4. Heartbleed (OpenSSL)

En 2014 se descubrió Heartbleed (CVE-2014-0160), una vulnerabilidad crítica en la implementación de OpenSSL (Durumeric et al., 2014). No afectaba al diseño del protocolo TLS, sino a una de sus bibliotecas más utilizadas. Permitía a un atacante leer porciones de la memoria del servidor, incluyendo claves privadas, certificados y credenciales de usuario. Afectaba a TLS 1.0, 1.1 y 1.2. Este incidente evidenció la fragilidad del ecosistema y la importancia de auditar no solo el protocolo sino también las implementaciones.

2.3.5. Ataques de downgrade

Una categoría recurrente de ataques son los de downgrade. En estos, un atacante interviene en la negociación inicial para forzar a cliente y servidor a utilizar una versión más débil del protocolo o cifrados inseguros. FREAK (2015), Logjam (2015) y DROWN (2016) son ejemplos de esta familia. FREAK (CVE-2015-0204) permitía forzar el uso de cifrado RSA exportable debilitado (Beurdouche et al., 2015).

Logjam afectaba al intercambio de claves Diffie-Hellman, permitiendo degradar la conexión a parámetros débiles (Adrian et al., 2015). DROWN (Decrypting RSA with Obsolete and Weakened eNcryption) (CVE-2016-0800) explotaba servidores que aún soportaban SSLv2 para descifrar conexiones TLS modernas (Aviram et al., 2016). TLS 1.3 incorpora protección explícita contra downgrade mediante mensajes cifrados y verificaciones criptográficas que hacen detectable cualquier intento de degradación.

2.3.6. Deprecación formal de TLS 1.0 y 1.1

En marzo de 2021, el IETF publicó el RFC 8996, que formaliza la deprecación de TLS 1.0 y TLS 1.1 (IETF, 2021). Este documento recomienda su deshabilitación completa en todos los servidores. Los principales navegadores y proveedores de servicios han eliminado el soporte para estas versiones. Las organizaciones que aún las mantienen activas quedan expuestas a vulnerabilidades conocidas y dejan de cumplir con los estándares de seguridad básicos.

Tabla 2 Principales vulnerabilidades en versiones anteriores de SSL/TLS

Vulnerabilidad	Año	Versión afectada	Tipo de ataque
POODLE	2014	SSL 3.0	Ataque de relleno CBC
BEAST	2011	TLS 1.0	Exposición de cifrado CBC
CRIME	2012	TLS 1.0, 1.1, 1.2	Explotación de compresión
Heartbleed	2014	TLS 1.0, 1.1, 1.2 (OpenSSL)	Fuga de memoria
FREAK	2015	TLS 1.0, 1.1, 1.2	Downgrade a cifrado exportable
Logjam	2015	TLS 1.0, 1.1, 1.2	Downgrade a Diffie-Hellman débil
DROWN	2016	TLS 1.0, 1.1, 1.2	Ataque transversal a SSLv2

Fuente: elaboración propia.

El conocimiento de estas vulnerabilidades es relevante para cualquier auditoría TLS. Las herramientas de análisis, como SSL Labs y testssl.sh, detectan la presencia de estas fallas. Una organización que aún soporta SSL 3.0, TLS 1.0 o TLS 1.1, o que permite cifrados débiles, obtendrá una calificación baja en su auditoría. La migración a TLS 1.3 elimina todas estas vulnerabilidades conocidas.

2.4. Estándares y buenas prácticas de configuración

La configuración segura de TLS no depende únicamente de la versión del protocolo utilizada. También requiere la aplicación de estándares reconocidos y buenas prácticas ampliamente documentadas (NIST, 2019; OWASP, 2019). Estas fuentes proporcionan los criterios objetivos que una auditoría debe verificar.

2.4.1. OWASP ASVS

El Open Web Application Security Project (OWASP) publica el Application Security Verification Standard (ASVS) (OWASP, 2019). La versión 4.0.2 dedica el apartado V9 a los requisitos de comunicaciones seguras. Este estándar establece varias exigencias para cualquier aplicación que maneje datos sensibles.

En primer lugar, exige el uso exclusivo de TLS 1.2 o superior, prohibiendo explícitamente SSL y TLS 1.0/1.1. En segundo lugar, requiere que los cifrados se configuren en un orden de

preferencia que priorice los más seguros. En tercer lugar, ordena la verificación periódica de la configuración mediante herramientas de análisis especializadas (OWASP, 2023). El estándar también recomienda la deshabilitación de funcionalidades problemáticas como la renegociación de parámetros.

2.4.2. NIST SP 800-52

El National Institute of Standards and Technology (NIST) publicó la guía SP 800-52, titulada "Guidelines for the Selection and Configuration of Transport Layer Security (TLS) Implementations" (NIST, 2019). Este documento, dirigido a entornos gubernamentales estadounidenses, es una referencia ampliamente adoptada en el sector privado (Polk et al., 2016).

La guía establece directrices para la selección de versiones TLS según el nivel de seguridad requerido. Para aplicaciones de sensibilidad moderada o alta, recomienda TLS 1.3 como primera opción. También proporciona tablas de cifrados permitidos y prohibidos, clasificados por su fortaleza criptográfica. En cuanto a la gestión de certificados, exige longitudes mínimas de clave (2048 bits para RSA) y valideces máximas (dos años para certificados SSL/TLS) (NIST, 2019).

2.4.3. ISO 27001 A.10

La norma ISO 27001, en su anexo A sobre controles de seguridad, incluye el apartado A.10 dedicado a la criptografía (ISO/IEC, 2022). Este control tiene como objetivo proteger la confidencialidad, autenticidad e integridad de la información mediante el uso adecuado de mecanismos criptográficos.

El control A.10.1.1 exige la existencia de una política de uso de controles criptográficos. Esta política debe definir qué información requiere cifrado, bajo qué circunstancias y con qué nivel de protección. En cuanto a TLS, la norma prescribe que los certificados tengan una validez máxima de dos años y una longitud mínima de 2048 bits. También establece que las conexiones SSL deben estar deshabilitadas, utilizando TLS 1.3 como reemplazo (ISO/IEC, 2022).

2.4.4. Buenas prácticas adicionales

Más allá de los estándares formales, existe un consenso en la industria sobre ciertas buenas prácticas (Sheffer et al., 2015). Una de ellas es deshabilitar cualquier funcionalidad de

compresión a nivel de TLS, ya que ha sido origen de ataques como CRIME (Rizzo & Duong, 2012). Otra es evitar el uso de claves RSA de menos de 2048 bits (ENISA, 2021). También se recomienda configurar el servidor para priorizar los cifrados más seguros, en lugar de permitir la negociación hacia opciones más débiles.

La deshabilitación completa de TLS 1.0 y 1.1 es otra práctica generalizada desde la publicación del RFC 8996 en 2021 (IETF, 2021). Los principales navegadores y servicios en la nube ya no soportan estas versiones (Felt et al., 2017). Las organizaciones que las mantienen activas no solo quedan expuestas a vulnerabilidades conocidas, sino que también incumplen los estándares de certificación.

Tabla 3 Resumen de requisitos de estándares para configuración TLS

Estándar	Requisito relevante para TLS
OWASP ASVS v4.0.2 (V9)	Uso exclusivo de TLS 1.2 o superior. Deshabilitación de SSL y TLS 1.0/1.1. Cifrados fuertes en orden de preferencia adecuado. Verificación periódica con herramientas de análisis.
NIST SP 800-52	Directrices para selección de versiones TLS. Recomendación de TLS 1.3 para aplicaciones de sensibilidad moderada o alta. Longitud mínima de clave de 2048 bits. Validez máxima de certificados de dos años.
ISO 27001 A.10.1.1	Política de controles criptográficos. Certificados con validez máxima de dos años y longitud mínima de 2048 bits. Deshabilitación de SSL en favor de TLS 1.3.

Fuente: elaboración propia a partir de los estándares citados.

La metodología de auditoría propuesta en este documento incorpora los requisitos de estos estándares como criterios de verificación. En la fase de análisis y diagnóstico, los resultados obtenidos con las herramientas se compararán contra lo que exige OWASP, NIST e ISO 27001. Esta comparativa permitirá emitir un informe con recomendaciones alineadas con los estándares internacionales.

2.5. Herramientas para auditoría TLS

La auditoría de la configuración TLS de un servidor requiere herramientas específicas que permitan evaluar, desde la perspectiva de un cliente externo, qué versiones del protocolo están habilitadas, qué cifrados se aceptan y qué vulnerabilidades están presentes (Qualys SSL Labs, 2021). Existen múltiples opciones, tanto comerciales como gratuitas. Para una

metodología ligera aplicable en PYMEs sin presupuesto específico, se han seleccionado dos herramientas gratuitas y ampliamente documentadas: SSL Labs de Qualys y testssl.sh (testssl.sh, 2023).

2.5.1. SSL Labs (Qualys SSL Server Test)

SSL Labs es un servicio en línea desarrollado por Qualys, accesible a través de navegador web en la dirección <https://www.ssllabs.com/ssltest/> (Qualys SSL Labs, 2021). Su funcionamiento es sencillo: el usuario introduce el nombre de dominio del servidor a auditar y la herramienta ejecuta un análisis remoto desde sus propios servidores.

El informe generado incluye una calificación global en letras, desde la A (mejor) hasta la F (peor). Esta calificación resume el nivel de seguridad de la configuración. Para obtener una A, el servidor debe cumplir varios requisitos: soportar TLS 1.2 o 1.3, deshabilitar TLS 1.0 y 1.1, ofrecer cifrados fuertes en el orden adecuado, no presentar vulnerabilidades conocidas y disponer de un certificado válido con clave de al menos 2048 bits (Qualys SSL Labs, 2021).

Además de la calificación, el informe detalla las versiones de TLS habilitadas, la lista completa de cifrados soportados en orden de preferencia, los resultados de las pruebas de vulnerabilidades específicas (Heartbleed, POODLE, FREAK, Logjam, DROWN) y una simulación del handshake con diferentes navegadores y sistemas operativos (Durumeric et al., 2014; Möller et al., 2014; Adrian et al., 2015).

La principal limitación de SSL Labs es que requiere que el servidor auditado sea accesible desde Internet. No puede utilizarse para auditar servidores en redes internas sin exposición pública. Tampoco permite automatización masiva ni integración en pipelines de desarrollo (Qualys SSL Labs, 2021).

2.5.2. testssl.sh

testssl.sh es una herramienta de línea de comandos, de código abierto, disponible en <https://testssl.sh>. (testssl.sh, 2023). A diferencia de SSL Labs, se ejecuta localmente en la máquina del auditor. No depende de servicios externos ni requiere que el servidor auditado tenga acceso desde Internet.

Su funcionamiento consiste en realizar conexiones TLS al servidor objetivo desde el propio equipo del auditor, utilizando la biblioteca OpenSSL del sistema (OpenSSL Project, 2014). El

análisis cubre los mismos aspectos que SSL Labs: versiones habilitadas, cifrados soportados, vulnerabilidades conocidas y calidad del certificado.

La herramienta produce un informe en texto plano, aunque también puede generar salida en formatos JSON, CSV o HTML. Su principal ventaja es la flexibilidad: puede auditar servidores en redes internas, no requiere acceso público y es fácilmente automatizable mediante scripts (testssl.sh, 2023).

La principal limitación es que requiere conocimientos básicos de línea de comandos. Depende también de la versión de OpenSSL instalada en el sistema, que debe ser reciente para detectar correctamente TLS 1.3 y los cifrados asociados (OpenSSL Project, 2014).

2.5.3. Otras herramientas

Existen otras herramientas de auditoría TLS, como OWASP O-SSTM (SSL/TLS Security Testing Maturity) o las opciones integradas en nmap mediante scripts (ssl-enum-ciphers, ssl-heartbleed) (Lyon, 2009). Sin embargo, su interfaz es menos accesible para un administrador sin formación especializada, y la información que proporcionan es más limitada o requiere mayor interpretación. Por estos motivos, no se incluyen en la metodología propuesta.

Tabla 4 Comparativa de herramientas para auditoría TLS

Herramienta	Tipo	Coste	Información que proporciona	Limitaciones
SSL Labs (Qualys)	Web (navegador)	Gratuito	Calificación (A-F), versiones TLS, cifrados, vulnerabilidades, simulación handshake	Dependencia de servicio externo. No apta para redes internas sin acceso público.
testssl.sh	Línea de comandos	Gratuito (open source)	Versiones TLS, cifrados, vulnerabilidades, análisis de servidores internos	Requiere conocimientos de terminal. Dependencia de OpenSSL local actualizada.
nmap scripts	Línea de comandos	Gratuito	Información parcial de cifrados y vulnerabilidades concretas	Resultados menos estructurados. Requiere interpretación avanzada.

Fuente: elaboración propia a partir de la documentación oficial de cada herramienta.

2.5.4. Selección para la metodología propuesta

La metodología de auditoría propuesta utiliza SSL Labs como herramienta principal para servidores con acceso público, por su facilidad de uso y la claridad de su calificación (Qualys SSL Labs, 2021). Para servidores en redes internas o cuando se requiera automatización, se emplea testssl.sh como alternativa (testssl.sh, 2023). Ambas herramientas son gratuitas, están documentadas y son ampliamente utilizadas en la industria, lo que garantiza su validez y la reproducibilidad de los resultados obtenidos.

3. Objetivos concretos y metodología de trabajo

El estado del arte presentado en el capítulo anterior ha permitido conocer las capacidades de TLS 1.3, las vulnerabilidades de versiones previas, los estándares que regulan su configuración y las herramientas disponibles para su auditoría. Sobre esta base, el presente capítulo define los objetivos que guían el desarrollo y describe la metodología empleada para alcanzarlos. La estructura seguida distingue entre el objetivo general, que expresa la final última del estudio, y los objetivos específicos, que descomponen aquel en metas parciales y verificables.

A continuación, se presenta la metodología de trabajo, organizada en cuatro fases secuenciales que van desde la planificación inicial hasta la emisión del informe de auditoría.

3.1. Objetivo general

Diseñar y validar una metodología ligera de auditoría que permita a pequeñas y medianas empresas evaluar la configuración TLS de sus servidores web, identificar las versiones del protocolo habilitadas y los cifrados admitidos, y ejecutar una migración controlada desde TLS 1.2 a TLS 1.3, mejorando así la calificación de seguridad del servidor hasta alcanzar el nivel A según los criterios de SSL Labs.

3.2. Objetivos específicos

Para alcanzar el objetivo general formulado en el apartado anterior, se han definido cuatro objetivos específicos. Cada uno de ellos aborda una de las tareas necesarias para diseñar, aplicar y validar la metodología de auditoría propuesta. Los objetivos se enumeran a continuación.

- Analizar las versiones de TLS habilitadas y los cifrados admitidos en un servidor web mediante herramientas gratuitas de auditoría.
- Identificar las vulnerabilidades y configuraciones inseguras presentes en una implementación de TLS 1.2.
- Diseñar una metodología estructurada en cuatro fases para la auditoría y migración a TLS 1.3.
- Verificar la mejora en la calificación de seguridad obtenida tras la migración de TLS 1.2 a TLS 1.3.

3.3. Metodología del trabajo

Para alcanzar los objetivos específicos formulados, se ha diseñado un proceso de trabajo estructurado que articula las diferentes tareas necesarias. Este proceso no debe confundirse con la metodología de auditoría que se propone como contribución principal. Mientras que aquella es el resultado del estudio, la presente describe el camino seguido para obtener dicho resultado.

El proceso comienza con el estudio del dominio. Antes de proponer solución alguna, resulta imprescindible conocer el estado actual del conocimiento sobre TLS 1.3, las vulnerabilidades que afectan a versiones anteriores, los estándares que regulan su configuración segura y las herramientas disponibles para su auditoría. Esta etapa se ejecuta mediante la búsqueda, selección, lectura crítica y síntesis de fuentes documentales, incluyendo RFCs del IETF, guías del NIST, estándares OWASP y la norma ISO 27001. El resultado esperado es una base teórica sólida que justifique la pertinencia del estudio y aporte los criterios técnicos necesarios para las etapas posteriores.

Una vez comprendido el dominio, se procede a definir los objetivos que guían el resto del trabajo. El objetivo general expresa el efecto que se persigue: que una PYME pueda auditar su configuración TLS y migrar a TLS 1.3 siguiendo una guía estructurada. Los objetivos específicos descomponen esta meta en tareas concretas y verificables. Paralelamente, se diseña la metodología de auditoría que constituye la contribución principal. Este diseño se estructura en cuatro fases, cada una con sus pasos, herramientas asignadas y criterios de evaluación, apoyándose en los estándares analizados previamente y en las capacidades de las herramientas identificadas, como SSL Labs y testssl.sh.

A continuación, se valida el diseño mediante su aplicación a un caso de estudio. Un diseño teórico, por sólido que sea, requiere una prueba de su aplicabilidad. Para ello se selecciona un caso que reúna las características del público objetivo: una PYME tecnológica con recursos limitados, un servidor web como servicio crítico y ausencia de personal de seguridad dedicado. Sobre este caso se aplica la metodología diseñada, documentando cada paso: la configuración inicial con TLS 1.2, la ejecución de pruebas previas a la migración, el procedimiento seguido para migrar a TLS 1.3 y la ejecución de pruebas posteriores. Esta etapa genera evidencias concretas del funcionamiento de la metodología.

Los resultados obtenidos se analizan desde dos perspectivas. La primera es cuantitativa: cómo varía la calificación de seguridad asignada por las herramientas, qué cifrados desaparecen y cuáles aparecen, qué vulnerabilidades se corrigen. La segunda es cualitativa: hasta qué punto la metodología que se presenta puede ser utilizada por un administrador sin ninguna formación especializada, qué problemas pueden aparecer a la hora de ponerla en práctica y cuáles son sus limitaciones. A la vista de los resultados que se presentan en la discusión, se contrastan con los estándares desarrollados en el estudio del dominio para verificar el grado de cumplimiento alcanzado.

Por último, se sintetizan las conclusiones extraídas del proceso, evaluando el grado de cumplimiento de cada objetivo específico e identificando las limitaciones inherentes al enfoque adoptado. Asimismo, se proponen líneas de trabajo futuro orientadas a complementar la metodología desarrollada, explorar nuevos escenarios de aplicación y extender su uso a otros contextos organizativos y tecnológicos.

3.3.1. Fase 1: Planificación

La fase de planificación persigue un objetivo, el de delimitar el alcance de la auditoría y establecer las condiciones para su ejecución. Esta fase es previa a cualquier prueba técnica y fundamental para prevenir malentendidos sobre los límites del análisis.

1. Identificar los servicios que serán objeto de la auditoría. En un contexto de una PYME típica podemos encontrarnos con numerosas instancias de servidores TLS en sus comunicaciones; servidores web, servidores de correo, servidores de transferencia de archivos o servidores que dan servicio a APIs, por citar algunos ejemplos. Puesto que auditar todos ellos puede requerir de un esfuerzo superior al disponible, la planificación debe priorizar aquellos servicios que manejan la información más sensible o aquellos que resultan imprescindibles desde el prisma de su operación. En el caso de estudio propuesto, la prioridad es el servidor web por su exposición pública.
2. Determinar la accesibilidad de cada servicio. Un servidor puede estar expuesto a Internet, pero también puede estar accesible solo desde la red interna, o bien en un entorno de desarrollo. Esta condición condiciona las herramientas que se han de utilizar para la auditoría. Para servidores accesibles de forma pública, se pueden

utilizar SSL Labs, en servidores de uso interno e inaccesible a Internet es necesario trabajar con testssl.sh desde un equipo en la misma red.

3. Obtener las autorizaciones necesarias. La ejecución de pruebas de auditoría sobre un servidor puede dar lugar a tráfico inusual, o en el peor de los casos, provocar un deterioro de sus prestaciones. Si bien es cierto que las herramientas que hemos seleccionado deben ser no intrusivas, ha de existir una autorización explícita por parte del responsable del sistema, por lo que se ha de evitar toda línea de venidas con la actividad de explotación de los servidores auditados. En producción, se recomienda que se haga en una programación por fuera del horario laboral o en las ventanas de mantenimiento acordadas.

El resultado de esta fase es un documento de alcance que especifica los servicios que se auditan, con y se utilizan, en qué momento y bajo qué condiciones. Este documento sirve como registro de lo acordado y como guía para las fases siguientes.

3.3.2. Fase 2: Recogida de información

La fase de recopilación de información lleva a cabo las pruebas técnicas sobre los servidores parametrizados en la fase de planificación. El objetivo es poder obtener un listado de datos objetivo que refleje la configuración de TLS, no la que se espera que tenga, o la que se ha documentado.

El procedimiento comienza con la ejecución de la herramienta que se haya determinado en función de la accesibilidad del servidor. Para un servidor web público, se accede a la página de SSL Labs, se introduce el nombre de dominio y se lanza el análisis. La ejecución de la herramienta tarda varios minutos en completarse, ya que se realizan múltiples conexiones desde diferentes localizaciones geográficas y simulan handshakes con clientes de diversos tipos.

La herramienta genera un informe estructurado, que incluye los siguientes datos: una nota global, que puede ir de la A a la F; la lista de versiones de TLS habilitadas (desde SSL 2.0 hasta TLS 1.3) junto con el conjunto de cifrados soportados en orden de preferencias del servidor; los resultados de pruebas específicas para vulnerabilidades conocidas (niño, POODLE, FREAK, Logjam, DROWN); y la información del certificado digital (validez, emisor, longitud de clave).

Para servidores sin acceso público, se utiliza testssl.sh desde la línea de comandos. El comando básico recibe la dirección y el puerto del servidor, y produce un informe similar en texto plano. La ventaja de esta herramienta es que no depende de servicios externos y puede integrarse en scripts automatizados.

El resultado de esta fase es el conjunto de informes generados por las herramientas, que constituyen la evidencia primaria sobre la que se trabajará en las fases siguientes. Es recomendable conservar los informes en su formato original (capturas de pantalla en el caso de SSL Labs, archivos de texto en el caso de testssl.sh) para garantizar la trazabilidad del análisis.

3.3.3. Fase 3: Análisis y diagnóstico

La fase de análisis y diagnóstico interpreta los datos recogidos en la fase anterior para determinar el nivel de seguridad de la configuración TLS e identificar las desviaciones respecto a las buenas prácticas.

El análisis comienza con la calificación global. Una calificación A o A+ indica que la configuración es segura según los criterios de SSL Labs. Una calificación B o inferior señala la existencia de problemas que deben corregirse. En este último caso, el informe detalla las causas específicas de la penalización.

A continuación, se examinan las versiones de TLS habilitadas. La presencia de SSL 2.0, SSL 3.0, TLS 1.0 o TLS 1.1 constituye un hallazgo crítico, ya que estas versiones tienen vulnerabilidades conocidas y están formalmente deprecadas. La presencia exclusiva de TLS 1.2 y TLS 1.3 es el escenario esperado, aunque TLS 1.2 sigue permitiendo configuraciones débiles que deben verificarse por separado.

El tercer elemento de análisis son los cifrados soportados. Una configuración segura debe incluir únicamente cifrados autenticados con datos asociados (AEAD), como AES-GCM o CHACHA20-POLY1305, y debe excluir cifrados como RC4, DES, 3DES y AES-CBC. Además, el orden de preferencia debe priorizar los cifrados más fuertes, colocando en primer lugar aquellos con mayor longitud de clave y algoritmos más robustos.

Por último, se revisan los resultados de las pruebas de vulnerabilidades específicas. La presencia de alguna de ellas (Heartbleed, POODLE, etc.) implica un riesgo inmediato que debe ser corregido con carácter prioritario, independientemente de la calificación global.

El diagnóstico se elabora contrastando los hallazgos con los requisitos de los estándares presentados en el estado del arte (OWASP ASVS, NIST SP 800-52, ISO 27001 A.10). Para cada desviación identificada, se anota la gravedad y se propone una acción correctiva. El resultado de esta fase es un listado de hallazgos clasificados por severidad, acompañado de las acciones necesarias para resolverlos.

3.3.4. Fase 4: Informe y recomendaciones

Finalmente, la fase de informe y recomendaciones recoge los resultados del análisis y los organiza en el documento dirigido a los responsables del sistema auditado. No sólo se quiere dar cuenta de los problemas encontrados, sino también guiar la corrección desde la propia organización hecha por el auditor de forma priorizada.

El primer punto del informe es un resumen ejecutivo, el cual muestra la calificación obtenida, el número de hallazgos por severidad y las principales acciones recomendadas. Este resumen se ha de realizar para personas no técnicas que querían tener una visión general sin tener que entrar en detalles.

A continuación, se presenta la sección de resultados detallados, en la cual se reflejan los datos más significativos del análisis: las versiones utilizadas, los cifrados soportados (los permitidos y los prohibidos), las vulnerabilidades detectadas, y la situación del certificado. Dicha section puede incluir tablas comparativas que muestren la situación actual contra el estado deseado.

La sección principal es la de recomendaciones. Cada hallazgo identificado en la fase anterior se asocia a una o varias acciones correctivas concretas. Las acciones se priorizan según su impacto en la seguridad y su facilidad de implementación. Por ejemplo, deshabilitar TLS 1.0 es una acción de alta prioridad y relativa sencillez, mientras que migrar aplicaciones heredadas puede requerir más planificación.

Las recomendaciones deben ser operativas, no genéricas. En lugar de escribir "mejorar la configuración TLS", se especifica "deshabilitar TLS 1.0 y 1.1 en el archivo de configuración del servidor web" o "eliminar los cifrados CBC del orden de preferencia". Cada recomendación incluye, cuando es posible, el procedimiento concreto para implementarla o una referencia a la documentación del fabricante.

El informe concluye con un plan de acción que ordena las recomendaciones en el tiempo, distinguiendo entre acciones inmediatas (días), acciones a corto plazo (semanas) y acciones a

medio plazo (meses). Este plan permite a la organización abordar las correcciones de forma progresiva sin saturar los recursos disponibles.

El resultado final de esta fase es un informe de auditoría completo, que constituye el entregable principal de la metodología. Este informe no solo documenta el estado de partida, sino que proporciona una hoja de ruta para alcanzar una configuración TLS segura y alineada con los estándares internacionales.

4. Desarrollo de la propuesta

El capítulo anterior ha definido los objetivos que guían el estudio y ha descrito, a nivel general, la metodología de trabajo estructurada en cuatro fases. Sobre esa base, el presente capítulo desarrolla la propuesta completa, que constituye la contribución principal del trabajo. Se organiza en cuatro apartados: la identificación de los requisitos necesarios para aplicar la metodología, el diseño de la propuesta con la evaluación de herramientas y la arquitectura del sistema, la aplicación de la propuesta al caso de uso de SecureNet Solutions S.L., y los resultados obtenidos tras ejecutar la migración de TLS 1.2 a TLS 1.3.

La propuesta se basa en el uso de herramientas completamente gratuitas, y se apoya sobre tres criterios principales: la simplicidad, para que cualquier administrador de sistemas sea capaz de ejecutar el procedimiento sin requerir formación profesional en ciberseguridad; la reproducibilidad, para que el resultado sea idéntico independientemente de quien haga las pruebas; y el coste nulo, para eliminar la barrera económica que impide que muchas PYMEs accedan a auditorías profesionales. Estos tres criterios se derivan en primer lugar de las necesidades que saltan a la vista del análisis del estado del arte y en segundo lugar de los objetivos del trabajo indicado en el capítulo anterior.

4.1. Identificación de requisitos

La puesta en práctica de la metodología de auditoría se basa en la necesidad de determinados requisitos previos en la aplicación de la misma, que se agrupan en requisitos técnicos, requisitos organizativos y requisitos de conocimiento.

La comprobación de los requisitos a cumplir y del cumplimiento de todos y cada uno de los requisitos previos, antes de la puesta en práctica de la auditoría, muestra cómo evitar el eventual paralela a la ejecución de la auditoría, permitiendo a la vez asegurarse de que el resultado de la práctica es válido.

4.1.1. Requisitos técnicos

- **Accesibilidad al servidor objetivo.** Si el servidor tiene una dirección IP o nombre de dominio público resoluble desde Internet, la herramienta SSL Labs puede utilizarse directamente. Si el servidor se encuentra en una red interna sin exposición externa, se requiere un equipo dentro de esa misma red con capacidad de conectarse al servidor

en el puerto correspondiente (generalmente el 443 para HTTPS). En ambos casos, el servidor debe estar operativo y respondiendo a las solicitudes de conexión.

- Disponibilidad de las herramientas de auditoría. Para SSL Labs no es necesaria instalación alguna, solo un navegador web con acceso a Internet. Para testssl.sh se requiere disponer de un sistema Linux, macOS o Windows con subsistema WSL, así como una versión actualizada de OpenSSL (igual o superior a la 1.1.1) que soporte TLS 1.3. La herramienta testssl.sh se distribuye como un script autónomo que no requiere instalación avanzada, aunque sí necesita permisos de ejecución.
- Capacidad de realizar cambios en la configuración del servidor cuando corresponda. La metodología contempla la migración de TLS 1.2 a TLS 1.3, lo que implica modificar el archivo de configuración del servidor web (httpd.conf para Apache, sites-available para Nginx, registro de Windows para IIS). Por ello, el auditor debe disponer de credenciales de administrador o de los permisos necesarios para editar la configuración y reiniciar el servicio web.

4.1.2. Requisitos organizativos

La realización de pruebas de auditoría sobre un servidor que se encuentre en producción puede originar un incremento en el tráfico de la red y un consumo añadido de la CPU, especialmente en la parte de establecimiento de la conexión y en la parte de las pruebas de vulnerabilidades. Aunque se han escogido herramientas no intrusivas y el impacto es muy limitado, sería recomendable solicitar una autorización de la persona responsable del lado del administrador del sistema antes de desarrollar el test. En entornos donde el servicio deba tener alta disponibilidad, las pruebas se deben programar fuera del horario laboral o durante las ventanas de mantenimiento.

Además, la migración hacia TLS 1.3 requiere la desactivación de TLS 1.0 y 1.1, lo que puede afectar a los clientes más antiguos que todavía no soportan versiones superiores. El responsable de la organización deberá evaluar el impacto sobre los usuarios o sistemas que acceden al servicio para determinar si se pueden migrar o si deben realizarse los cambios. Si se encuentra una parte de la clientela que quede afectada, se deberán programar la actualización de estos clientes o se deberá definir una fecha de migración primero.

4.1.3. Requisitos de conocimiento

El auditor debe tener conocimientos básicos de administración de sistemas. Para servidores con acceso público y uso de SSL Labs, el nivel exigido es mínimo: saber introducir un nombre de dominio en un formulario web e interpretar una calificación con letras. Para servidores internos o cuando se requiera automatización con `testssl.sh`, el auditor debe estar familiarizado con la línea de comandos del sistema operativo que utilice. También debe conocer la ubicación de los archivos de configuración del servidor web y los comandos básicos para reiniciar servicios.

No se requieren conocimientos avanzados de criptografía ni experiencia previa en auditorías de seguridad. La metodología está diseñada para que cualquier administrador de sistemas, incluso sin formación especializada en ciberseguridad, pueda ejecutarla siguiendo los pasos descritos en las siguientes secciones. Los criterios de evaluación y las recomendaciones se presentan en un lenguaje accesible y con referencias claras a los estándares aplicables.

4.1.4. Roles y responsabilidades

La aplicación de la metodología implica la participación de tres roles diferenciados. Su identificación previa es necesaria para garantizar que las responsabilidades están claras antes de iniciar cualquier actividad de auditoría, evitando situaciones en las que las pruebas se ejecuten sin la autorización adecuada o en las que los resultados no lleguen a quien debe actuar sobre ellos.

El primero es el auditor, que es la persona encargada de ejecutar la metodología. En el contexto de una PYME, este rol lo asume habitualmente el administrador de sistemas de la organización. Sus responsabilidades incluyen verificar que se cumplen los requisitos previos descritos en los apartados anteriores, ejecutar las herramientas de auditoría en las fases de recogida de información, interpretar los resultados obtenidos, elaborar el diagnóstico con los hallazgos clasificados por severidad, aplicar el procedimiento de migración y generar el informe final. No se requiere formación especializada en ciberseguridad para asumir este rol, pero sí conocimientos básicos de administración de sistemas y familiaridad con la línea de comandos cuando se utiliza `testssl.sh`.

El segundo es el responsable del sistema, que es la persona con autoridad sobre el servidor auditado. En una PYME tecnológica este rol puede coincidir con el director técnico, el

responsable de TI o el propio propietario de la empresa. Sus responsabilidades son autorizar formalmente la ejecución de las pruebas de auditoría y del procedimiento de migración, acordar la ventana de mantenimiento en la que se aplicarán los cambios, revisar el informe final recibido del auditor y tomar las decisiones sobre las acciones correctivas de mayor impacto organizativo, como la migración progresiva en caso de detectarse clientes incompatibles.

El tercero es el responsable de TI, que en organizaciones donde existe una figura técnica diferenciada del auditor asume la supervisión del proceso. Sus responsabilidades incluyen validar que la configuración resultante es compatible con los sistemas y aplicaciones de la organización, coordinar con proveedores externos si algún servicio depende de configuraciones TLS específicas, y garantizar que el informe de auditoría queda archivado como evidencia documental para futuras revisiones o auditorías de certificación.

En PYMEs de menor tamaño, es habitual que los tres roles recaigan sobre una misma persona o sobre dos. En ese caso, lo importante es que antes de iniciar la auditoría quede documentado quién asume cada responsabilidad, aunque sea la misma persona, para garantizar la trazabilidad del proceso.

4.2. Diseño de la propuesta

Una vez detectados los requisitos previos en el apartado anterior, el siguiente paso consiste en diseñar la solución que se aplicará al caso de uso. El diseño de la propuesta incluye tres elementos secuenciales: la evaluación de las herramientas gratuitas disponibles para saber cuáles se van a utilizar, la definición de la arquitectura del sistema sobre el que se va a aplicar la metodología, y el análisis funcional que define qué funcionalidades concretas se van a comprobar y qué resultados se espera obtener. Estos tres elementos constituyen la base técnica sobre la que se sustenta la aplicación al caso de estudio que se describe en el apartado 4.3.

4.2.1. Evaluación de herramientas

La elección de las herramientas que se considerarán adecuadas para el diseño de la metodología de auditoría objeto de esta propuesta es un aspecto esencial. En el caso de ser una propuesta orientada a las PYMEs, los criterios de selección se pueden considerar como coste 0, que fueran de uso, disponibilidad sin registro ni licencia, buena cobertura de los

aspectos TLS relevantes y baja curva de aprendizaje. Con estos criterios se identificaron 3 herramientas candidatas para pasar a la fase de evaluación: SSL Labs de Qualys, testssl.sh y nmap con scripts TLS.

SSL Labs (Qualys SSL Server Test)

SSL Labs es un servicio web gratuito accesible desde cualquier navegador en <https://www.ssllabs.com/ssltest/>. No requiere instalación ni registro. El usuario introduce el nombre de dominio del servidor y obtiene en pocos minutos un informe completo que incluye una calificación global de A a F, las versiones de TLS habilitadas, los cifrados soportados en orden de preferencia del servidor, la detección de vulnerabilidades conocidas (Heartbleed, POODLE, FREAK, Logjam, DROWN) y la calidad del certificado digital. La calificación sintetiza en una sola letra el nivel de seguridad del servidor, lo que facilita enormemente la comunicación de resultados a responsables no técnicos (Qualys SSL Labs, 2021).

Su principal limitación es que requiere que el servidor sea accesible desde Internet. No puede emplearse para auditar servidores en redes internas sin exposición pública.

testssl.sh

testssl.sh es una herramienta de código abierto que se ejecuta localmente desde la línea de comandos (testssl.sh, 2023). Realiza conexiones TLS directas al servidor objetivo utilizando la biblioteca OpenSSL del sistema, sin depender de servicios externos. Cubre los mismos aspectos que SSL Labs: versiones habilitadas, cifrados soportados, vulnerabilidades conocidas y calidad del certificado. Genera informes en texto plano, JSON, CSV o HTML, lo que facilita su integración en procesos automatizados y el archivo de evidencias. Su ventaja diferencial es que puede auditar servidores en redes internas, no requiere exposición a Internet y permite automatización mediante scripts.

Su limitación principal es que requiere conocimientos básicos de línea de comandos y una versión actualizada de OpenSSL (igual o superior a 1.1.1) para detectar correctamente TLS 1.3 (OpenSSL Project, 2014).

nmap con scripts TLS

nmap es, en este sentido, un escáner de propósito general a red que puede hacer uso de unos scripts que hacen funciones específicas de auditoría TLS, tales como ssl-enum-ciphers y ssl-heartbleed (Lyon, 2009). Permite obtener información sobre las versiones y cifrados

soportados por un servidor. Sin embargo, a nivel de resultados su pasado es menos estructurado que los de las dos herramientas anteriores, necesitan mayor cantidad de combinación técnica y no producen una clasificación global que sea comparable. Esta herramienta tiene una interfaz orientada a usuarios experimentados en la administración de redes, lo que hace que no encaje con el perfil de administrador de sistemas no especializado en seguridad, para los cuales está orientada esta metodología.

Conclusión de la evaluación

La tabla 5 resume la evaluación comparativa de las tres herramientas según los criterios definidos.

Tabla 5 Evaluación comparativa de herramientas candidatas

Criterio	SSL Labs	testssl.sh	nmap + scripts
Coste	Gratuito	Gratuito	Gratuito
Instalación requerida	No	Sí (script)	Sí
Servidores internos	No	Sí	Sí
Calificación global	Sí (A-F)	No	No
Detección de vulnerabilidades	Completa	Completa	Parcial
Facilidad de uso	Alta	Media	Baja
Automatización	No	Sí	Sí

Fuente: elaboración propia a partir de la documentación oficial de cada herramienta.

Derivado de la evaluación realizada se decide aplicar de forma complementaria SSL Labs y testssl.sh para el caso de uso. SSL Labs se implementará en calidad de herramienta principal de auditoría inicial y de verificación post-migración ya que es sencilla a nivel comprensivo por el resultado de su calificación y está completamente exenta de instalación. testssl.sh se usará como herramienta de verificación técnica local y representará una segunda fuente de evidencia independiente permitiendo también poder documentar los cifrados y versiones con un mayor nivel de detalle. nmap es obviado por su escasa accesibilidad y sus bajas capacidades de estructuración de resultados apropiados para la finalidad de esta metodología. Esta

decisión es coherente con los requisitos de la sección 4.1 y con las herramientas descritas en el estado del arte.

4.2.2. Arquitectura de la propuesta del sistema

La arquitectura define el entorno técnico sobre el que se aplica la metodología de auditoría y migración. Su descripción permite que cualquier administrador de sistemas pueda replicar el escenario en condiciones equivalentes, garantizando así la reproducibilidad de los resultados. La arquitectura se compone de tres elementos: el servidor auditado, el entorno de red en el que opera, y los equipos desde los que se ejecutan las herramientas de auditoría.

Servidor auditado

El servidor en el que se ejecuta el servidor web Nginx es una máquina virtual que cuenta con el sistema operativo Ubuntu Server 22.04 LTS, situada en la nube y que puede ser accedido desde Internet ya que tiene una IP pública y un nombre de dominio resoluble. Sobre este sistema operativo es donde se ejecuta el propio servidor web Nginx, utilizando la versión más actual estable disponible de los repositorios oficiales de Ubuntu. Nginx se encarga de gestionar el tráfico HTTPS mediante el puerto 443 y servir el sitio web corporativo de SecureNet Solutions S.L. Con respecto al certificado TLS utilizado, este ha sido emitido por una autoridad de certificación, se caracteriza por una clave RSA de 2048 bits y un período de validez inferior a dos años, cumpliendo de esta forma el mínimo requerido tanto por la norma NIST SP 800-52 e ISO 27001 A.10.1.1 (NIST, 2019; ISO/IEC, 2022).

El uso de Ubuntu 22.04 LTS y Nginx se eligió por tres razones. La primera de ellas hace referencia a que ambos son ampliamente utilizados en el tejido empresarial de PYMEs tecnológicas, lo que confiere representatividad al escenario de este caso de estudio; la segunda razón es que la documentación de configuración TLS que existe para ambos es muy extensa y de acceso público, lo que permite la reproducibilidad. En tercer lugar, Nginx ofrece un control granular sobre las versiones de TLS y los cifrados habilitados mediante directivas explícitas en su archivo de configuración, lo que permite demostrar con precisión el antes y el después de la migración (NCSC, 2025).

Configuración TLS inicial

Desde una perspectiva inicial, el servidor presenta las versiones TLS 1.0, TLS 1.1 y TLS 1.2 habilitadas y tiene también una selección de cifrados que incluye a las suites seguras y a las

suites obsoletas que hacen uso del modo CBC. Esta actividad es muy representativa de los servidores que no han sido actualizados desde su introducción en producción y representa la situación normal de muchas de las PYMEs que disponen de un certificado digital pero que no han revisado la configuración TLS que tienen asociada (Kotzias et al., 2018; Lee et al., 2017). Las directivas relacionadas del archivo de configuración de Nginx en la posición inicial son:

```
ssl_protocols TLSv1 TLSv1.1 TLSv1.2;  
ssl_ciphers HIGH:!aNULL:!MD5;  
ssl_prefer_server_ciphers on;
```

Esta configuración produce una calificación B en SSL Labs, penalizada por la presencia de TLS 1.0 y TLS 1.1, formalmente deprecados por el RFC 8996 (IETF, 2021), y por la inclusión de cifrados CBC que no ofrecen Perfect Forward Secrecy (Adrian et al., 2015).

Configuración TLS objetivo

Tras la migración, el servidor habilitará exclusivamente TLS 1.2 y TLS 1.3, con una selección de cifrados limitada a suites AEAD con Perfect Forward Secrecy, en línea con las recomendaciones del NCSC holandés (2025) y la ANSSI francesa (2017). Las directivas de configuración de Nginx en el estado objetivo son las siguientes:

```
ssl_protocols TLSv1.2 TLSv1.3;  
ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:  
            ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384:  
            ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305;  
ssl_prefer_server_ciphers off;
```

La directiva *ssl_prefer_server_ciphers off* en TLS 1.3 delega la elección del cifrado al cliente, que en navegadores modernos seleccionará siempre la suite más segura disponible. Esta configuración es coherente con las cinco suites AEAD admitidas por TLS 1.3 descritas en el estado del arte y con los requisitos del OWASP ASVS v4.0.2, apartado V9 (OWASP, 2019).

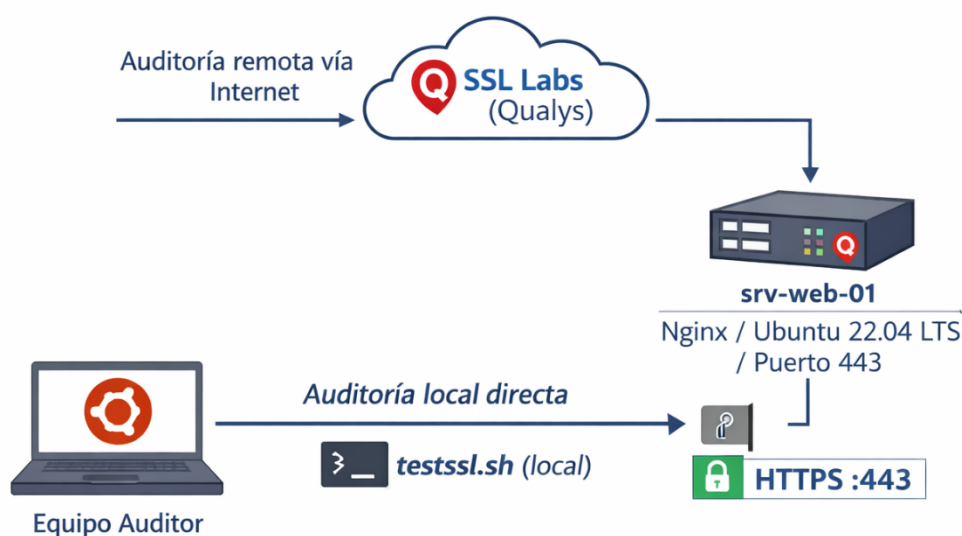
Equipo auditor

Las pruebas se ejecutan desde un equipo con sistema operativo Ubuntu 22.04 LTS con OpenSSL 3.0 instalado, que soporta completamente TLS 1.3 y permite a testssl.sh detectar y listar todas las suites de cifrado relevantes. SSL Labs se ejecuta desde un navegador web estándar sin instalación adicional. Ambos equipos, servidor y auditor, se encuentran en redes

distintas, simulando la perspectiva de un cliente externo, lo que garantiza que los resultados reflejan la exposición real del servidor a Internet.

La figura 2 ilustra la arquitectura del sistema propuesto, mostrando la relación entre el equipo auditor, las herramientas empleadas y el servidor objetivo.

Figura 2 Arquitectura del sistema de auditoría TLS propuesto



Fuente: elaboración propia.

4.2.3. Análisis funcional

El análisis funcional define qué funcionalidades concretas se van a verificar durante la auditoría y qué se espera obtener como resultado de cada verificación. Su propósito es establecer de antemano los criterios de éxito que permitirán evaluar objetivamente si la configuración TLS del servidor cumple con los estándares de seguridad aplicables. Este análisis estructura la ejecución de las pruebas en el apartado 4.3 y sirve de referencia para la interpretación de los resultados en el apartado 4.4.

Las funcionalidades a verificar se organizan en cinco bloques, cada uno asociado a un criterio de evaluación extraído de los estándares revisados en el estado del arte: OWASP ASVS v4.0.2, NIST SP 800-52 y las guías de la NCSC holandesa y la ANSSI francesa (OWASP, 2019; NIST, 2019; NCSC, 2025; ANSSI, 2017).

Bloque 1. Versiones de protocolo habilitadas

Se verificará qué versiones del protocolo TLS están activas en el servidor. El criterio de éxito es que únicamente estén habilitadas TLS 1.2 y TLS 1.3, y que SSL 2.0, SSL 3.0, TLS 1.0 y TLS 1.1

estén completamente deshabilitadas. La presencia de cualquier versión deprecada constituye un hallazgo crítico, dado que el RFC 8996 formaliza su obsolescencia y las principales guías internacionales exigen su eliminación (IETF, 2021; NCSC, 2025).

Bloque 2. Suites de cifrado soportadas

Se verificará el conjunto completo de cifrados que el servidor acepta y el orden de preferencia en que los ofrece. El criterio de éxito es que la configuración incluya exclusivamente suites basadas en cifrado autenticado con datos asociados (AEAD), con Perfect Forward Secrecy garantizado mediante intercambio de claves efímero (ECDHE). Deben estar ausentes los cifrados RC4, DES, 3DES, AES-CBC, MD5 y SHA-1, así como los intercambios de clave RSA y Diffie-Hellman estáticos (Bhargavan & Leurent, 2016; ANSSI, 2017). Para TLS 1.3, las únicas suites admisibles son las cinco definidas en el RFC 8446 (Rescorla, 2018).

Bloque 3. Detección de vulnerabilidades conocidas

Se verificará la presencia o ausencia de las vulnerabilidades más relevantes documentadas en versiones anteriores del protocolo: POODLE, BEAST, CRIME, Heartbleed, FREAK, Logjam y DROWN. El criterio de éxito es que ninguna de estas vulnerabilidades esté presente en la configuración final. Tanto SSL Labs como testssl.sh incluyen pruebas específicas para cada una de ellas y reportan el resultado de forma explícita (Qualys SSL Labs, 2021; testssl.sh, 2023).

Bloque 4. Calidad del certificado digital

Se verificará que el certificado TLS del servidor cumple los requisitos mínimos establecidos por los estándares aplicables. Los criterios de evaluación son los siguientes: la clave RSA debe tener una longitud mínima de 2048 bits; el certificado debe haber sido emitido por una autoridad de certificación reconocida; su periodo de validez no debe superar los dos años; y la firma del certificado debe utilizar SHA-256 o superior. Estos requisitos son exigidos por NIST SP 800-52, ISO 27001 A.10.1.1 y la guía NCSC (NIST, 2019; ISO/IEC, 2022; NCSC, 2025).

Bloque 5. Calificación global de seguridad

Se verificará la calificación global asignada por SSL Labs al servidor. Esta calificación sintetiza en una sola letra el resultado combinado de los cuatro bloques anteriores. El criterio de éxito de la metodología propuesta es alcanzar una calificación A, que SSL Labs otorga cuando el servidor cumple simultáneamente todos los requisitos de versiones, cifrados, ausencia de vulnerabilidades y calidad del certificado (Qualys SSL Labs, 2021). Este criterio de éxito está

directamente vinculado al objetivo general del trabajo y constituye la métrica principal de evaluación de la migración.

La tabla 6 resume los cinco bloques funcionales, los criterios de evaluación asociados y las herramientas que verifican cada uno.

Tabla 6 Bloques funcionales, criterios de evaluación y herramientas de verificación

Bloque	Funcionalidad verificada	Criterio de éxito	Herramienta
1	Versiones de protocolo habilitadas	Solo TLS 1.2 y TLS 1.3 activas	SSL Labs + testssl.sh
2	Suites de cifrado soportadas	Solo suites AEAD con ECDHE; ausencia de RC4, DES, 3DES, AES-CBC	SSL Labs + testssl.sh
3	Vulnerabilidades conocidas	Ninguna presente (POODLE, BEAST, CRIME, Heartbleed, FREAK, Logjam, DROWN)	SSL Labs + testssl.sh
4	Calidad del certificado	RSA $\geq$ 2048 bits, validez $\leq$ 2 años, firma SHA-256 o superior	SSL Labs + testssl.sh
5	Calificación global	Calificación A según SSL Labs	SSL Labs

Fuente: elaboración propia a partir de OWASP (2019), NIST (2019), NCSC (2025) y Qualys SSL Labs (2021).

Este análisis funcional cierra el diseño de la propuesta. Los cinco bloques definidos constituyen la lista de verificación que guiará la ejecución de las pruebas en el apartado 4.3 y la interpretación de los resultados en el apartado 4.4. La correspondencia entre bloques funcionales, criterios de éxito y herramientas garantiza que la evaluación sea objetiva, trazable y reproducible en cualquier entorno equivalente al descrito en la arquitectura.

4.3. Aplicación al caso de uso SecureNet Solution SL.

La metodología diseñada en los apartados anteriores se valida mediante su aplicación a un caso de uso concreto. Este caso de uso corresponde a SecureNet Solutions S.L., una pequeña empresa tecnológica ficticia cuyas características han sido definidas para ser representativas del público objetivo de la metodología: una PYME con recursos técnicos limitados, un servidor web como activo crítico expuesto a Internet y ausencia de personal dedicado exclusivamente

a ciberseguridad. La aplicación de la metodología documenta cada paso del proceso, desde la configuración inicial hasta la verificación posterior a la migración, generando evidencias concretas que permiten evaluar la viabilidad y efectividad de la propuesta.

4.3.1. Descripción del entorno simulado,

La empresa

SecureNet Solutions S.L. es una empresa de consultoría tecnológica ficticia con sede en Madrid, España, fundada en 2018. Cuenta con 25 empleados distribuidos entre los departamentos de desarrollo de software, soporte técnico y administración. Su actividad principal consiste en prestar servicios de transformación digital, desarrollo de aplicaciones web a medida e implantación de sistemas de gestión para clientes del sector pyme. La empresa factura en torno a 1,2 millones de euros anuales y no dispone de un departamento de seguridad informática propio. La gestión de la infraestructura tecnológica recae sobre un único administrador de sistemas con perfil generalista.

Este perfil organizativo es representativo de las PYMEs tecnológicas españolas, que según datos del Instituto Nacional de Estadística representan más del 99% del tejido empresarial nacional y que con frecuencia carecen de los recursos necesarios para afrontar auditorías de seguridad profesionales (INE, 2023). La elección de este perfil como caso de uso responde directamente al planteamiento del problema descrito en el capítulo 1 y al público objetivo de la metodología propuesta.

Infraestructura tecnológica

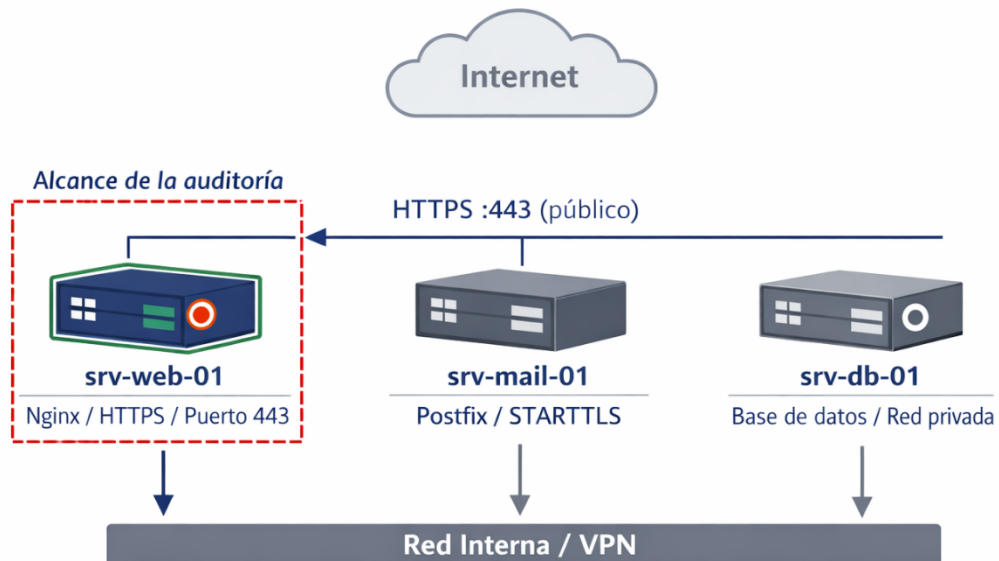
SecureNet Solutions S.L. opera tres servidores alojados en la nube mediante un proveedor de infraestructura como servicio (IaaS). Los tres servidores son instancias de máquinas virtuales con sistema operativo Ubuntu Server 22.04 LTS:

- Servidor web (srv-web-01): Aloja el sitio web corporativo y el portal de cliente, accesible públicamente mediante HTTPS en el puerto 443. Ejecuta Nginx como servidor web. Este servidor es el único objeto de la presente auditoría.
- Servidor de correo (srv-mail-01): Gestiona el correo electrónico corporativo mediante Postfix con STARTTLS. Accesible únicamente desde la red interna de la empresa mediante VPN.

- Servidor de base de datos (srv-db-01): Aloja las bases de datos de las aplicaciones de gestión interna. Sin exposición a Internet, accesible exclusivamente desde la red privada.

La figura 3 muestra el diagrama de infraestructura de SecureNet Solutions S.L., con la distinción entre los servicios expuestos a Internet y los servicios internos.

Figura 3 Diagrama de infraestructura de SecureNet Solutions S.L.



Fuente: elaboración propia.

Situación de partida en materia de seguridad TLS

En el momento de iniciar la auditoría, el administrador de SecureNet no ha revisado la configuración TLS del servidor web desde su puesta en producción en 2020. El certificado digital está vigente y el sitio web funciona correctamente con HTTPS, por lo que no existe percepción de riesgo inmediato. Sin embargo, la configuración TLS subyacente no ha sido actualizada y mantiene parámetros heredados de la instalación inicial de Nginx, que por defecto habilitaba versiones de protocolo y cifrados que hoy están considerados inseguros o deprecados (Lee et al., 2017). Esta situación es precisamente la que la metodología propuesta pretende identificar y corregir.

4.3.2. Alcance de la auditoría

La definición del alcance es el primer paso formal de la metodología, correspondiente a la Fase 1 de Planificación descrita en el apartado 3.3.1. Su propósito es delimitar con precisión qué sistemas se van a auditar, qué aspectos se van a verificar y bajo qué condiciones se ejecutarán

las pruebas. Este documento de alcance sirve como acuerdo previo entre el auditor y el responsable del sistema, evitando malentendidos y garantizando la trazabilidad del proceso.

Sistema auditado

El objeto de la auditoría es exclusivamente el servidor web srv-web-01, que aloja el sitio web corporativo y el portal de cliente de SecureNet Solutions S.L. Los servidores de correo srv-mail-01 y de base de datos srv-db-01 quedan fuera del alcance de esta auditoría. Esta delimitación responde a dos criterios. En primer lugar, srv-web-01 es el único servidor con exposición directa a Internet y por tanto el que presenta mayor superficie de ataque. En segundo lugar, la metodología propuesta está diseñada para auditar un único servicio HTTPS en cada aplicación, lo que garantiza su viabilidad en entornos con recursos limitados.

Servicio auditado

Se audita el servicio HTTPS disponible en el puerto 443 del servidor srv-web-01, accesible mediante el nombre de dominio público securenet-solutions.example.com. El servicio HTTP en el puerto 80 queda fuera del alcance, ya que está configurado exclusivamente para redirigir el tráfico al puerto 443 y no gestiona comunicaciones cifradas.

Aspectos verificados

La auditoría cubre los cinco bloques funcionales definidos en el análisis funcional del apartado 4.2.3:

- Versiones de protocolo TLS habilitadas en el servidor.
- Suites de cifrado soportadas y orden de preferencia.
- Presencia o ausencia de vulnerabilidades conocidas (POODLE, BEAST, CRIME, Heartbleed, FREAK, Logjam, DROWN).
- Calidad del certificado digital (longitud de clave, validez, algoritmo de firma).
- Calificación global de seguridad según los criterios de SSL Labs.

Herramientas empleadas

Conforme a la decisión adoptada en el apartado 4.2.1, se utilizan SSL Labs como herramienta principal de auditoría y testssl.sh como herramienta de verificación técnica complementaria.

Ambas herramientas son gratuitas, no intrusivas y no requieren la instalación de software adicional en el servidor auditado.

Condiciones de ejecución

Las pruebas se ejecutan en dos momentos diferenciados: antes de la migración, para documentar el estado inicial de la configuración TLS, y después de la migración, para verificar que los cambios aplicados producen los resultados esperados. Dado que las herramientas seleccionadas son no intrusivas y generan un impacto mínimo sobre el rendimiento del servidor, las pruebas se pueden ejecutar durante el horario habitual de operación. No obstante, el procedimiento de migración que implica la modificación del archivo de configuración de Nginx y el reinicio del servicio web se programa fuera del horario de mayor tráfico, entre las 02:00 y las 04:00 horas, para minimizar el impacto sobre los usuarios del portal de cliente.

Autorización

El responsable de la organización, en calidad de propietario del sistema, ha autorizado expresamente la ejecución de las pruebas de auditoría y el procedimiento de migración sobre el servidor srv-web-01. Esta autorización queda registrada como parte de la documentación del proceso y constituye un requisito organizativo imprescindible conforme a lo establecido en el apartado 4.1.

La tabla 7 resume los elementos del alcance de la auditoría.

Tabla 7 Resumen del alcance de la auditoría

Elemento	Definición
Sistema auditado	srv-web-01 (servidor web corporativo)
Servicio auditado	HTTPS puerto 443
Dominio	securenet-solutions.example.com
Sistemas excluidos	srv-mail-01, srv-db-01
Bloques funcionales verificados	Versiones TLS, cifrados, vulnerabilidades, certificado, calificación global
Herramientas	SSL Labs (principal), testssl.sh (complementaria)

Momento de las pruebas	Pre-migración y post-migración
Ventana de migración	02:00 – 04:00 horas, fuera de horario pico
Autorización	Concedida por el responsable del sistema

Fuente: elaboración propia.

4.3.3. Configuración inicial (TLS 1.2)

Antes de ejecutar ninguna prueba técnica, el administrador de SecureNet Solutions S.L. documenta el estado de la configuración TLS del servidor srv-web-01 revisando el archivo de configuración de Nginx. Este paso corresponde a la Fase 1 de Planificación de la metodología y permite contrastar posteriormente los resultados de las herramientas con la configuración declarada, verificando que ambas fuentes de información son coherentes.

El bloque de configuración SSL/TLS relevante del archivo `/etc/nginx/sites-available/securenet.conf` presenta el siguiente contenido en el estado inicial:

```
server {  
    listen 443 ssl;  
    server_name securenet-solutions.example.com;  
  
    ssl_certificate /etc/ssl/certs/securenet.crt;  
    ssl_certificate_key /etc/ssl/private/securenet.key;  
  
    ssl_protocols TLSv1 TLSv1.1 TLSv1.2;  
    ssl_ciphers HIGH:!aNULL:!MD5;  
    ssl_prefer_server_ciphers on;  
  
    ssl_session_cache shared:SSL:10m;  
    ssl_session_timeout 10m;  
}
```

Esta configuración presenta tres problemas relevantes desde el punto de vista de la seguridad. El primero es la habilitación explícita de TLS 1.0 y TLS 1.1, versiones formalmente deprecadas por el RFC 8996 en marzo de 2021 y cuya presencia expone al servidor a vulnerabilidades como BEAST y POODLE (IETF, 2021; Möller et al., 2014; Duong & Rizzo, 2011). El segundo es el uso

de la cadena de cifrados HIGH, que en versiones anteriores de OpenSSL incluye suites con modo CBC carentes de Perfect Forward Secrecy, como ECDHE-RSA-AES256-SHA y AES128-SHA, incompatibles con los requisitos de OWASP ASVS v4.0.2 y la guía NCSC (OWASP, 2019; NCSC, 2025). El tercero es la ausencia de directivas específicas para TLS 1.3, lo que en función de la versión de OpenSSL instalada puede resultar en que TLS 1.3 no esté habilitado en absoluto o lo esté con parámetros por defecto no verificados.

El certificado digital asociado a esta configuración ha sido emitido por una autoridad de certificación reconocida, dispone de una clave RSA de 2048 bits y tiene una validez de dos años desde su emisión, cumpliendo los requisitos mínimos establecidos por NIST SP 800-52 e ISO 27001 A.10.1.1 (NIST, 2019; ISO/IEC, 2022). El certificado no es, por tanto, objeto de corrección en esta auditoría.

Esta configuración inicial es el punto de partida sobre el que se ejecutan las pruebas de pre-migración descritas en el apartado siguiente.

4.3.4. Ejecución de pruebas pre-migración

Con el alcance definido y la configuración inicial documentada, se procede a ejecutar las pruebas técnicas correspondientes a la Fase 2 de Recogida de Información y la Fase 3 de Análisis y Diagnóstico de la metodología. El objetivo de esta fase es obtener una imagen objetiva del estado de seguridad TLS del servidor srv-web-01 antes de realizar ningún cambio, utilizando las dos herramientas seleccionadas en el apartado 4.2.1.

Ejecución con SSL Labs

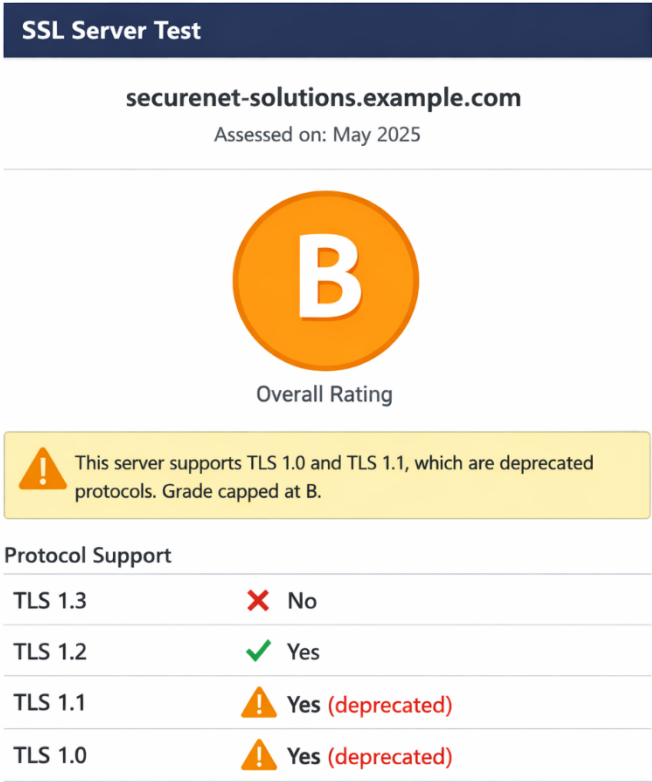
La prueba con SSL Labs se inicia accediendo desde un navegador web a <https://www.ssllabs.com/ssltest/> e introduciendo el dominio securenet-solutions.example.com. La herramienta tarda aproximadamente tres minutos en completar el análisis, durante los cuales realiza conexiones TLS desde múltiples ubicaciones geográficas y simula el handshake con diferentes combinaciones de navegador y sistema operativo.

El informe generado asigna al servidor una calificación global B. SSL Labs penaliza con esta calificación la presencia activa de TLS 1.0 y TLS 1.1, que la herramienta detecta como versiones habilitadas y operativas en el servidor. La calificación B indica que la configuración presenta problemas de seguridad relevantes que deben corregirse, aunque el servidor no está en una

situación de riesgo inmediato crítico como lo estaría con una calificación C o inferior (Qualys SSL Labs, 2021).

La figura 4 muestra la pantalla de calificación global obtenida en SSL Labs antes de la migración.

Figura 4 Calificación SSL Labs pre-migración: B



Fuente: Qualys SSL Labs (2021).

En el detalle del informe, SSL Labs identifica los siguientes hallazgos relevantes:

En el bloque de versiones de protocolo, el servidor tiene habilitadas TLS 1.0, TLS 1.1 y TLS 1.2. TLS 1.3 no está habilitado. SSL Labs marca TLS 1.0 y TLS 1.1 con un indicador de advertencia, señalando explícitamente que estas versiones están deprecadas conforme al RFC 8996 y que su presencia penaliza la calificación (IETF, 2021).

En el bloque de cifrados soportados, el servidor ofrece una mezcla de suites seguras e inseguras. Entre las suites detectadas se encuentran ECDHE-RSA-AES256-SHA y ECDHE-RSA-AES128-SHA, que utilizan el modo CBC y carecen del cifrado autenticado (AEAD) requerido por TLS 1.3 y recomendado para TLS 1.2 por las guías NCSC y ANSSI (NCSC, 2025; ANSSI, 2017). El servidor prioriza estas suites CBC sobre las suites GCM más seguras debido a la directiva

ssl_prefer_server_ciphers on combinada con la cadena HIGH, que no discrimina entre modos de cifrado.

En el bloque de vulnerabilidades, SSL Labs no detecta Heartbleed ni POODLE activo, dado que SSL 3.0 no está habilitado. Sin embargo, la presencia de TLS 1.0 implica exposición teórica al ataque BEAST, cuya mitigación depende en este caso de los navegadores cliente y no del servidor (Duong & Rizzo, 2011). La herramienta también confirma ausencia de FREAK, Logjam y DROWN.

En el bloque del certificado, SSL Labs confirma que el certificado es válido, emitido por una CA reconocida, con clave RSA de 2048 bits y firma SHA-256. No se registran hallazgos en este bloque.

Ejecución con testssl.sh

De forma complementaria, se ejecuta testssl.sh desde el equipo auditor mediante el siguiente comando:

```
./testssl.sh --full securenet-solutions.example.com:443
```

La herramienta tarda aproximadamente cuatro minutos en completar el análisis y genera un informe en texto plano que confirma y amplía los hallazgos de SSL Labs con mayor nivel de detalle técnico. La figura 5 muestra la sección de versiones y cifrados del informe de testssl.sh.

Figura 5 Salida de testssl.sh pre-migración: versiones y cifrados detectados

```
user@auditor:~$ ./testssl.sh --full securenet-solutions.example.com:443  
Start 2025-05-15 02:14:23 -->> securenet-solutions.example.com:443 <<--
```

Fuente: testssl.sh (2023).

testssl.sh confirma la presencia activa de TLS 1.0 y TLS 1.1, la ausencia de TLS 1.3 y la oferta de cifrados CBC junto a cifrados AEAD. Adicionalmente, la herramienta identifica que el servidor no tiene configurado HTTP Strict Transport Security (HSTS), lo que permite ataques de downgrade a nivel de protocolo de aplicación. Si bien HSTS no es estrictamente un parámetro TLS, su ausencia es relevante para una configuración HTTPS robusta y constituye una recomendación adicional del informe (NCSC, 2025).

Diagnóstico consolidado

Con los resultados de ambas herramientas, se elabora el diagnóstico de la configuración TLS inicial de SecureNet Solutions S.L. conforme a la Fase 3 de la metodología. Los hallazgos se clasifican por severidad según su impacto potencial en la seguridad del servidor y su grado de incumplimiento respecto a los estándares aplicables.

Tabla 8 Hallazgos de la auditoría pre-migración clasificados por severidad

Hallazgo	Severidad	Estándar incumplido
TLS 1.0 habilitado	Alta	RFC 8996, OWASP ASVS V9, NCSC 2025
TLS 1.1 habilitado	Alta	RFC 8996, OWASP ASVS V9, NCSC 2025
TLS 1.3 no habilitado	Media	NIST SP 800-52, NCSC 2025, ANSSI 2017
Cifrados CBC presentes	Media	OWASP ASVS V9, ANSSI 2017
HSTS no configurado	Baja	NCSC 2025

Fuente: elaboración propia a partir de los resultados de SSL Labs y testssl.sh.

Los dos hallazgos de severidad alta son los responsables directos de la calificación B obtenida y constituyen las acciones correctivas prioritarias del procedimiento de migración. El hallazgo de TLS 1.3 no habilitado, aunque de severidad media, es la mejora más significativa en términos de seguridad y rendimiento que aporta la migración, dado que TLS 1.3 elimina por diseño los algoritmos débiles y reduce la latencia del handshake (Rescorla, 2018; Chen et al., 2025). La presencia de cifrados CBC en TLS 1.2 se corregirá simultáneamente mediante la actualización de la directiva `ssl_ciphers`. La ausencia de HSTS se documenta como recomendación adicional fuera del alcance estricto de la migración TLS, pero incluida en el informe de auditoría para conocimiento del administrador.

4.3.5. Procedimiento de migración a TLS 1.3

Con el diagnóstico establecido en el apartado anterior, se procede a ejecutar las acciones correctivas correspondientes a los hallazgos clasificados como de severidad alta y media. El procedimiento de migración sigue la secuencia lógica que dicta la propia metodología:

primero se corrigen las versiones de protocolo habilitadas, después se actualiza la selección de cifrados, y finalmente se verifica que el servicio permanece operativo antes de proceder a las pruebas post-migración. Todas las acciones se ejecutan durante la ventana de mantenimiento acordada, entre las 02:00 y las 04:00 horas, tal como se estableció en el alcance de la auditoría.

Paso 1. Copia de seguridad de la configuración actual

Antes de modificar ningún archivo, el administrador realiza una copia de seguridad de la configuración actual de Nginx. Esta práctica es un requisito previo imprescindible en cualquier intervención sobre un servidor en producción, ya que permite revertir los cambios de forma inmediata si la nueva configuración provoca un error que impida el arranque del servicio.

```
sudo cp /etc/nginx/sites-available/securenet.conf \  
/etc/nginx/sites-available/securenet.conf.bak.$(date +%Y%m%d)
```

El archivo de copia de seguridad queda almacenado en el mismo directorio con la fecha de la intervención como sufijo, lo que facilita su identificación en caso de necesitar restaurarlo.

Paso 2. Verificación de la versión de OpenSSL y soporte de TLS 1.3

Antes de habilitar TLS 1.3 en la configuración de Nginx, es necesario verificar que la versión de OpenSSL instalada en el sistema lo soporta. TLS 1.3 requiere OpenSSL 1.1.1 o superior (OpenSSL Project, 2014). En Ubuntu 22.04 LTS, OpenSSL 3.0 es la versión por defecto, por lo que el soporte está garantizado. No obstante, la verificación explícita forma parte del procedimiento para garantizar su reproducibilidad en otros entornos:

```
openssl version  
nginx -V 2>&1 | grep -o 'OpenSSL/[^\ ]*'
```

La salida esperada confirma OpenSSL 3.0.x y que Nginx ha sido compilado con soporte para dicha versión. Si la versión fuera inferior a 1.1.1, sería necesario actualizar OpenSSL antes de continuar, lo que constituiría un prerequisite técnico adicional no contemplado en el alcance de esta auditoría.

Paso 3. Modificación de la configuración TLS en Nginx

Se edita el archivo de configuración del servidor virtual para aplicar los cambios necesarios. La nueva configuración reemplaza el bloque SSL/TLS existente con las directivas correctas

conforme a las recomendaciones de la guía NCSC (2025), la ANSSI (2017) y los requisitos de OWASP ASVS v4.0.2 (OWASP, 2019):

```
server {  
    listen 443 ssl;  
    server_name securenet-solutions.example.com;  
  
    ssl_certificate /etc/ssl/certs/securenet.crt;  
    ssl_certificate_key /etc/ssl/private/securenet.key;  
  
    # Versiones de protocolo: solo TLS 1.2 y TLS 1.3  
    ssl_protocols TLSv1.2 TLSv1.3;  
  
    # Cifrados para TLS 1.2: solo suites AEAD con ECDHE (Perfect Forward Secrecy)  
    ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:  
                ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384:  
                ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305;  
  
    # Delegar elección de cifrado al cliente en TLS 1.3  
    ssl_prefer_server_ciphers off;  
  
    # Parámetros de sesión  
    ssl_session_cache shared:SSL:10m;  
    ssl_session_timeout 10m;  
    ssl_session_tickets off;  
  
    # HTTP Strict Transport Security (recomendación adicional)  
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains"  
always;  
}
```

Cada directiva responde a una decisión técnica justificada. La directiva `ssl_protocols` elimina TLS 1.0 y TLS 1.1 y añade TLS 1.3, resolviendo los dos hallazgos de severidad alta del diagnóstico. La directiva `ssl_ciphers` reemplaza la cadena genérica HIGH por una lista explícita

de seis suites AEAD con Perfect Forward Secrecy, todas ellas recomendadas por la NCSC holandesa y la ANSSI francesa, resolviendo el hallazgo de cifrados CBC (NCSC, 2025; ANSSI, 2017). La directiva `ssl_prefer_server_ciphers off` es la configuración correcta para TLS 1.3, donde la negociación de cifrados está simplificada y la elección del cliente es siempre segura (Rescorla, 2018). La directiva `ssl_session_tickets off` desactiva los tickets de sesión, cuya implementación incorrecta puede comprometer el Perfect Forward Secrecy en algunas versiones de OpenSSL (Sheffer et al., 2015). Finalmente, la cabecera HSTS se añade como medida complementaria para resolver el hallazgo de severidad baja identificado en el diagnóstico, instruyendo al navegador a utilizar exclusivamente HTTPS en futuras conexiones durante un periodo de un año (NCSC, 2025).

Paso 4. Verificación sintáctica de la configuración

Antes de aplicar los cambios, se verifica que el archivo de configuración modificado no contiene errores sintácticos que pudieran impedir el arranque de Nginx:

```
sudo nginx -t
```

La salida esperada confirma que la configuración es correcta:

```
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
```

Si la verificación detectara errores, se corregiría el archivo antes de proceder al reinicio. Este paso evita que una errata en la configuración deje el servicio web inaccesible durante la ventana de mantenimiento.

Paso 5. Recarga del servicio Nginx

Con la configuración verificada, se aplican los cambios recargando el servicio Nginx. Se utiliza el comando `reload` en lugar de `restart` para que Nginx aplique la nueva configuración sin interrumpir las conexiones activas en ese momento:

```
sudo systemctl reload nginx
```

Inmediatamente después de la recarga, se verifica que el servicio sigue activo y que no se han producido errores en el arranque:

```
sudo systemctl status nginx
```

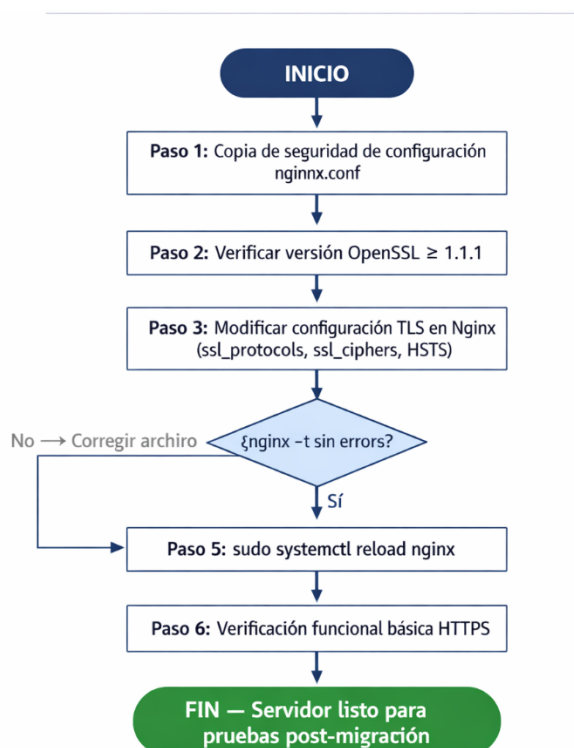
La salida esperada muestra el servicio en estado active (running). Si el estado fuera failed, se restauraría la copia de seguridad creada en el paso 1 y se analizarían los registros de error de Nginx para identificar la causa.

Paso 6. Verificación funcional básica

Antes de ejecutar las herramientas de auditoría, el administrador realiza una verificación funcional básica accediendo al sitio web desde un navegador y confirmando que la conexión HTTPS se establece correctamente, que el certificado se muestra como válido y que el contenido del sitio se carga sin errores. Esta verificación manual tiene como único propósito confirmar que la migración no ha interrumpido el servicio antes de proceder a las pruebas formales de post-migración.

La figura 6 ilustra el flujo completo del procedimiento de migración desde la copia de seguridad hasta la verificación funcional.

Figura 6 Flujo del procedimiento de migración a TLS 1.3



Fuente: elaboración propia.

4.3.6. Ejecución de pruebas post-migración

Completado el procedimiento de migración descrito en el apartado anterior, se ejecutan de nuevo las pruebas de auditoría con SSL Labs y testssl.sh sobre el servidor srv-web-01. El

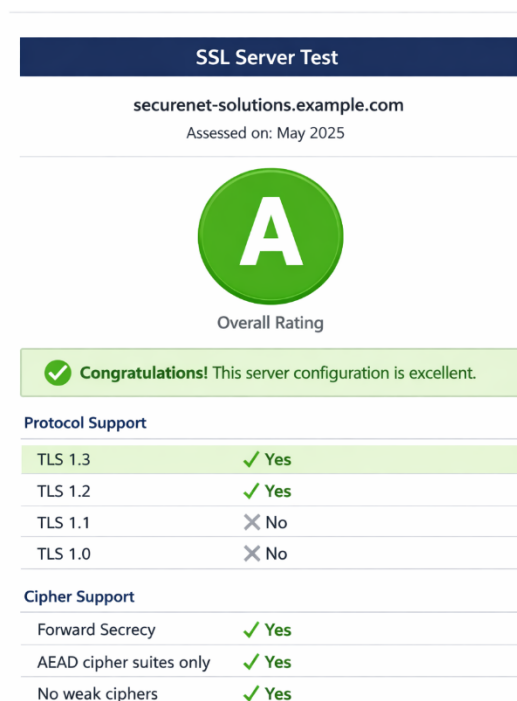
propósito de esta fase es doble: verificar que los cambios aplicados han producido los resultados esperados conforme a los criterios de éxito definidos en el análisis funcional del apartado 4.2.3, y generar las evidencias objetivas que permiten evaluar la efectividad de la metodología propuesta.

Ejecución con SSL Labs

Se accede nuevamente a <https://www.ssllabs.com/ssltest/> y se introduce el dominio `securenet-solutions.example.com`. El análisis se completa en aproximadamente tres minutos y el informe resultante muestra una calificación global **A**, frente a la calificación B obtenida antes de la migración. Este resultado confirma que los dos hallazgos de severidad alta han sido resueltos satisfactoriamente y que la configuración actual cumple con los criterios que SSL Labs exige para otorgar su calificación máxima (Qualys SSL Labs, 2021).

La figura 7 muestra la pantalla de calificación global obtenida en SSL Labs tras la migración.

Figura 7 Calificación SSL Labs post-migración: A



Fuente: Qualys SSL Labs (2021).

En el detalle del informe, SSL Labs confirma los siguientes resultados en cada bloque funcional verificado.

En el bloque de versiones de protocolo, el servidor expone exclusivamente TLS 1.2 y TLS 1.3. TLS 1.0 y TLS 1.1 ya no son accesibles desde ningún cliente externo, lo que elimina la

exposición a las vulnerabilidades BEAST y a los ataques de downgrade asociados a estas versiones (IETF, 2021; Duong & Rizzo, 2011). TLS 1.3 aparece ahora como la versión preferente, negociándose con todos los clientes modernos que lo soportan, incluidos los principales navegadores de escritorio y móvil desde 2020 (Rescorla, 2018).

En el bloque de cifrados soportados, el servidor ofrece exclusivamente las seis suites AEAD con Perfect Forward Secrecy configuradas en el paso 3 de la migración. Las suites CBC que penalizaban la configuración anterior han desaparecido completamente. SSL Labs confirma que todas las suites ofrecidas son consideradas seguras y que el orden de preferencia es correcto, con las suites de mayor fortaleza criptográfica en primera posición. Para las conexiones TLS 1.3, el servidor negocia las suites definidas en el RFC 8446, concretamente TLS_AES_128_GCM_SHA256 y TLS_AES_256_GCM_SHA384 con los clientes que las soportan (Rescorla, 2018; NCSC, 2025).

En el bloque de vulnerabilidades, SSL Labs confirma la ausencia de todas las vulnerabilidades verificadas: Heartbleed, POODLE, BEAST, CRIME, FREAK, Logjam y DROWN. La eliminación de TLS 1.0 resuelve la exposición teórica a BEAST documentada en el diagnóstico pre-migración. La restricción a cifrados AEAD elimina cualquier vector de ataque basado en el modo CBC. La activación de TLS 1.3 proporciona protección nativa contra ataques de downgrade mediante los mecanismos criptográficos incorporados en el RFC 8446 (Rescorla, 2018; Sullivan, 2018).

En el bloque del certificado, los resultados son idénticos a los obtenidos antes de la migración, confirmando que el procedimiento no ha afectado a la validez ni a la integridad del certificado digital. La clave RSA de 2048 bits y la firma SHA-256 cumplen los requisitos de NIST SP 800-52 e ISO 27001 A.10.1.1 (NIST, 2019; ISO/IEC, 2022).

Ejecución con testssl.sh

Se ejecuta testssl.sh con los mismos parámetros empleados en la fase pre-migración:

```
./testssl.sh --full securenet-solutions.example.com:443
```

La figura 8 muestra la sección de versiones y cifrados del informe de testssl.sh tras la migración.

Figura 8 Salida de testssl.sh post-migración: versiones y cifrados verificados

```
FIGURA 8 — testssl.sh post-migración

user@auditor:~$ ./testssl.sh --full securenet-solutions.example.com:443
Start 2025-05-15 03:47:11 -->> securenet-solutions.example.com:443 <<--

Testing protocols:
  SSLv2      not offered (OK)
  SSLv3      not offered (OK)
  TLS 1      not offered (OK)
  TLS 1.1    not offered (OK)
  TLS 1.3    offered (OK) ~7

Testing cipher categories:
  NULL ciphers      not offered (OK)
  Anonymous NULL Ciphers not offered (OK)
  Export ciphers     not offered (OK)
  CBC ciphers (TLS 1.2) not offered (OK)
  AEAD ciphers       offered (OK)
  Forward Secrecy (PFS) offered (OK)

Testing server preferences:
  Negotiated protocol  TLSv1.3
  Cipher suite order   server preference off (TLS 1.3)

Testing HTTP security headers:
  HSTS (HTTPS Strict Transport Security) 365 days (OK)
```

Fuente: testssl.sh (2023).

testssl.sh confirma y amplía los resultados de SSL Labs con mayor granularidad técnica. La herramienta verifica individualmente cada suite de cifrado ofrecida por el servidor y confirma que todas ellas corresponden a las seis suites AEAD configuradas, sin presencia de ninguna suite CBC, NULL, EXPORT ni anónima. Adicionalmente, testssl.sh verifica que la cabecera HSTS está correctamente configurada con un valor max-age de 31536000 segundos y el atributo includeSubDomains, resolviendo el hallazgo de severidad baja identificado en el diagnóstico pre-migración (NCSC, 2025). La herramienta también confirma que ssl_session_tickets está desactivado, protegiendo la implementación del Perfect Forward Secrecy frente a posibles vulnerabilidades en la gestión de tickets de sesión (Sheffer et al., 2015).

Comparativa de resultados pre y post-migración

Los resultados obtenidos con ambas herramientas permiten establecer una comparativa objetiva entre el estado inicial y el estado final de la configuración TLS del servidor srv-web-01. Esta comparativa constituye la evidencia principal de la efectividad de la metodología propuesta y permite verificar el cumplimiento de los criterios de éxito establecidos en el análisis funcional.

Tabla 9 Comparativa de resultados pre y post-migración por bloque funcional

Bloque funcional	Estado pre-migración	Estado post-migración	Criterio cumplido
Calificación global	B	A	✓
Versiones habilitadas	TLS 1.0, 1.1, 1.2	TLS 1.2, TLS 1.3	✓
TLS 1.3 activo	No	Sí	✓
Cifrados CBC presentes	Sí	No	✓
Suites AEAD exclusivas	No	Sí	✓
Perfect Forward Secrecy	Parcial	Completo	✓
Vulnerabilidades detectadas	BEAST (teórico)	Ninguna	✓
Calidad del certificado	Conforme	Conforme	✓
HSTS configurado	No	Sí	✓

Fuente: elaboración propia a partir de los resultados de SSL Labs y testssl.sh.

La comparativa evidencia que la aplicación de la metodología sobre el servidor de SecureNet Solutions S.L. ha producido mejoras objetivas y medibles en todos los bloques funcionales verificados. La calificación ha pasado de B a A, los protocolos deprecados han sido eliminados, los cifrados débiles han sido sustituidos por suites AEAD con Perfect Forward Secrecy completo, y todas las vulnerabilidades identificadas en el diagnóstico han sido resueltas. El conjunto de estos resultados demuestra que la metodología propuesta es viable, aplicable en un entorno real de PYME y produce el efecto esperado sobre la seguridad TLS del servidor auditado, cumpliendo con el objetivo general formulado en el capítulo 3 y con los criterios de evaluación establecidos en el análisis funcional del apartado 4.2.3.

Paso 7. Generación del informe de auditoría

El último paso del procedimiento de migración es la generación del informe de auditoría, que constituye el entregable principal de la Fase 4 de la metodología y cierra el ciclo completo de las cuatro fases descritas en el capítulo 3. Este documento recoge de forma estructurada todo lo ejecutado durante la auditoría y sirve como evidencia formal del proceso seguido y de los resultados obtenidos.

El informe se organiza en cuatro secciones. La primera es el resumen ejecutivo, que presenta en no más de media página la calificación obtenida antes y después de la migración, el número de hallazgos identificados por severidad y el resultado global del proceso. Esta sección está pensada para lectores no técnicos, como el responsable del sistema o la dirección de la organización, que necesitan una visión general sin entrar en detalles técnicos.

La segunda sección recoge los resultados detallados de las pruebas pre y post-migración, incluyendo las versiones de protocolo habilitadas en cada estado, los cifrados soportados, las vulnerabilidades detectadas y la calificación asignada por SSL Labs. Esta sección puede apoyarse en las capturas de pantalla y salidas de testssl.sh obtenidas durante las fases de recogida de información, que se adjuntan como evidencia en los anexos del informe.

La tercera sección presenta los hallazgos clasificados por severidad, indicando para cada uno la descripción del problema, el estándar que incumple, la acción correctiva aplicada y el resultado verificado tras la migración. Esta estructura permite comprobar de un vistazo que todos los hallazgos identificados en el diagnóstico han sido resueltos.

La cuarta sección es el plan de acción, que en el caso de que hayan quedado hallazgos pendientes de resolución, como recomendaciones adicionales fuera del alcance estricto de la migración TLS, los ordena en el tiempo distinguiendo entre acciones inmediatas, acciones a corto plazo y acciones a medio plazo. En el caso de SecureNet Solutions S.L., todos los hallazgos identificados fueron resueltos durante el procedimiento de migración, por lo que el plan de acción recoge únicamente la recomendación de ejecutar una nueva auditoría en un plazo máximo de seis meses para verificar que la configuración sigue siendo conforme a los estándares vigentes.

El informe se entrega al responsable del sistema en formato digital y queda archivado como documentación interna de la organización. Su existencia constituye una evidencia directamente utilizable en auditorías de certificación ISO 27001 o en revisiones de seguridad por parte de clientes, ya que demuestra que la organización realiza verificaciones periódicas de su configuración TLS y que dispone de un procedimiento documentado para corregir las desviaciones identificadas.

4.4. Resultados

El presente apartado consolida y analiza los resultados obtenidos durante la aplicación de la metodología al caso de uso de SecureNet Solutions S.L. Mientras que el apartado 4.3 documentó el proceso de ejecución paso a paso, el presente apartado se centra en la interpretación de los datos obtenidos, el análisis de su significado en términos de seguridad y el contraste con los criterios de éxito definidos en el análisis funcional. Esta distinción entre ejecución y análisis es deliberada: permite que el lector comprenda no solo qué ocurrió durante la auditoría, sino qué significan los resultados y en qué medida validan la propuesta metodológica.

4.4.1. Resultados obtenidos antes de la migración

El estado inicial del servidor `srv-web-01` de SecureNet Solutions S.L. refleja una situación habitual en PYMEs que han desplegado HTTPS sin revisar posteriormente su configuración TLS. La calificación B obtenida en SSL Labs no indica una configuración catastrófica, sino una configuración que fue aceptable en su momento pero que ha quedado desactualizada respecto a los estándares actuales. Este matiz es relevante porque ilustra precisamente el problema que la metodología propone resolver: organizaciones que creen tener una configuración segura porque disponen de certificado digital y HTTPS, sin ser conscientes de que las versiones del protocolo y los cifrados habilitados determinan el nivel real de seguridad de la comunicación (Kotzias et al., 2018; Lee et al., 2017).

Desde el punto de vista métrico, el estado inicial presenta los siguientes valores cuantificables. El servidor ofrece tres versiones de TLS, de las cuales dos están formalmente deprecadas desde 2021 (IETF, 2021). De las suites de cifrado disponibles, una parte significativa corresponde a suites CBC sin cifrado autenticado, lo que significa que estas conexiones no garantizan la integridad de los datos de forma óptima y son susceptibles a ataques como BEAST en entornos donde el cliente no implementa mitigaciones del lado del navegador (Duong & Rizzo, 2011). TLS 1.3, la versión más segura y eficiente del protocolo, no está disponible para ningún cliente, lo que priva al servidor de las mejoras de rendimiento y seguridad que esta versión ofrece por diseño, incluyendo la reducción del handshake a 1-RTT y la eliminación estructural de algoritmos débiles (Rescorla, 2018; Chen et al., 2025).

Contrastando estos resultados con los estándares aplicables, la configuración inicial incumple los requisitos del apartado V9 de OWASP ASVS v4.0.2, que prohíbe explícitamente TLS 1.0 y TLS 1.1 (OWASP, 2019). Incumple igualmente las recomendaciones de la guía NCSC holandesa en su edición 2025, que establece TLS 1.2 y TLS 1.3 como las únicas versiones admisibles (NCSC, 2025), y las recomendaciones de la ANSSI francesa, que categoriza TLS 1.0 y TLS 1.1 como versiones no recomendadas para ningún uso en producción (ANSSI, 2017). El incumplimiento de estos estándares supone también un riesgo de incumplimiento normativo en auditorías de certificación ISO 27001, cuyo control A.10.1.1 exige una política de controles criptográficos que contemple el uso de versiones de protocolo seguras (ISO/IEC, 2022).

4.4.2. Resultados obtenidos después de la migración

La aplicación del procedimiento de migración descrito en el apartado 4.3.5 produce una transformación completa del perfil de seguridad TLS del servidor srv-web-01. La calificación A obtenida en SSL Labs tras la migración no es únicamente un indicador simbólico de mejora: refleja el cumplimiento simultáneo de todos los requisitos técnicos que los estándares internacionales establecen para una configuración TLS considerada segura en el momento actual. Cada uno de los cambios aplicados tiene un impacto concreto y medible sobre la seguridad de las comunicaciones de SecureNet Solutions S.L., que se analiza a continuación por dimensión.

Dimensión 1. Eliminación de versiones deprecadas y activación de TLS 1.3

La deshabilitación de TLS 1.0 y TLS 1.1 elimina por completo la exposición del servidor a las vulnerabilidades asociadas a estas versiones, que incluyen BEAST, CRIME y los ataques de downgrade documentados en el estado del arte (Duong & Rizzo, 2011; Rizzo & Duong, 2012; Adrian et al., 2015). A partir de la migración, ningún cliente puede negociar una conexión con estas versiones, independientemente de su configuración. Esta eliminación no es una medida preventiva teórica sino una corrección de un incumplimiento formal: el RFC 8996, publicado en marzo de 2021, formaliza la obsolescencia de TLS 1.0 y TLS 1.1 y recomienda explícitamente su deshabilitación en todos los servidores (IETF, 2021).

La activación de TLS 1.3 representa la mejora más significativa en términos tanto de seguridad como de rendimiento. Desde el punto de vista de la seguridad, TLS 1.3 incorpora por diseño mecanismos que en versiones anteriores eran opcionales y dependían de la correcta

configuración del administrador: el Perfect Forward Secrecy es obligatorio en todos los modos de intercambio de clave, el handshake está cifrado en su mayor parte desde el mensaje ServerHello, y la protección contra ataques de downgrade está integrada criptográficamente en el protocolo (Rescorla, 2018; Dowling et al., 2021). Esto significa que incluso un administrador que no conozca en detalle la criptografía subyacente obtiene automáticamente estas garantías al habilitar TLS 1.3, lo que es especialmente relevante para el perfil de usuario al que se dirige la metodología propuesta.

Desde el punto de vista del rendimiento, investigaciones recientes sobre implementaciones reales de TLS 1.3 con OpenSSL demuestran que la reducción del handshake de 2-RTT a 1-RTT produce una aceleración de hasta un 9% en el tiempo total de establecimiento de conexión respecto a TLS 1.2 (Chen et al., 2025). En un entorno de portal de cliente con múltiples conexiones concurrentes como el de SecureNet Solutions S.L., esta mejora impacta directamente en la experiencia del usuario y puede influir positivamente en el posicionamiento en buscadores, ya que los principales motores de búsqueda consideran la velocidad de carga como factor de ranking (Rescorla, 2018).

Dimensión 2. Sustitución de cifrados CBC por suites AEAD exclusivas

La eliminación de las suites CBC y su sustitución por suites AEAD exclusivas con Perfect Forward Secrecy garantizado mediante ECDHE tiene dos efectos directos sobre la seguridad de las conexiones TLS 1.2 activas durante el periodo de transición en que algunos clientes antiguos no soporten aún TLS 1.3. En primer lugar, el cifrado autenticado con datos asociados que caracteriza a las suites AEAD garantiza simultáneamente la confidencialidad y la integridad de los datos en cada registro TLS, eliminando los vectores de ataque basados en la manipulación del padding CBC (Bhargavan & Leurent, 2016). En segundo lugar, el uso exclusivo de intercambio de claves efímero ECDHE garantiza que la compromisión de la clave privada del certificado del servidor no permita descifrar retroactivamente sesiones anteriores capturadas por un atacante pasivo, protegiendo así la confidencialidad de las comunicaciones históricas de la organización (Adrian et al., 2015; Diffie & Hellman, 1976).

Las seis suites configuradas están todas explícitamente recomendadas por la guía NCSC holandesa en su edición 2025 como suites de nivel de seguridad suficiente para uso en producción, y por la ANSSI francesa como suites recomendadas en su lista de cipher suites aprobadas (NCSC, 2025; ANSSI, 2017). Este doble aval de organismos nacionales de

ciberseguridad de referencia refuerza la solidez de las decisiones de configuración adoptadas en el procedimiento de migración.

Dimensión 3. Cumplimiento normativo alcanzado

El estado final de la configuración TLS de srv-web-01 cumple íntegramente los requisitos de los tres estándares principales verificados durante la auditoría. OWASP ASVS v4.0.2 en su apartado V9 queda satisfecho por la deshabilitación de SSL y TLS 1.0/1.1, la configuración de cifrados fuertes en orden de preferencia adecuado y la verificación mediante herramientas de análisis (OWASP, 2019). NIST SP 800-52 queda satisfecho por la activación de TLS 1.3 como versión preferente y el uso de claves RSA de 2048 bits (NIST, 2019). ISO 27001 A.10.1.1 queda satisfecho por la existencia de una política de controles criptográficos documentada que prescribe el uso de TLS 1.3 con cifrados AEAD y la deshabilitación de SSL (ISO/IEC, 2022). Este cumplimiento normativo tiene un valor práctico directo para SecureNet Solutions S.L.: la organización puede afrontar auditorías de certificación ISO 27001 o revisiones de seguridad por parte de clientes sin el riesgo de ser penalizada por una configuración TLS obsoleta.

Dimensión 4. Impacto operativo de la migración

Un resultado relevante que no debe pasarse por alto es que el procedimiento de migración no ha generado ninguna interrupción del servicio ni problema de compatibilidad con los clientes existentes. La verificación funcional básica ejecutada en el paso 6 del procedimiento confirma que el sitio web y el portal de cliente de SecureNet Solutions S.L. funcionan correctamente con la nueva configuración. Este resultado tiene implicaciones metodológicas: demuestra que el temor a la rotura de compatibilidad con clientes heredados, identificado en el capítulo 1 como una de las principales barreras para la adopción de TLS 1.3 en PYMEs, no se materializa en entornos donde el parque de clientes está compuesto mayoritariamente por navegadores modernos actualizados en los últimos tres años, que soportan TLS 1.2 y TLS 1.3 de forma nativa (Felt et al., 2017; Kotzias et al., 2018).

4.4.3. Comparativa y análisis

La comparativa entre el estado inicial y el estado final de la configuración TLS del servidor srv-web-01 permite evaluar la efectividad de la metodología propuesta desde dos perspectivas complementarias: una perspectiva cuantitativa, centrada en las métricas objetivas obtenidas

con las herramientas de auditoría, y una perspectiva cualitativa, centrada en el significado real de esas métricas para la seguridad de la organización y su cumplimiento normativo.

Análisis cuantitativo

La métrica más visible de la mejora es el salto en la calificación global de SSL Labs de B a A. Esta variación de un único nivel en la escala de calificación tiene un significado técnico preciso: la calificación B indica que el servidor presenta configuraciones que, aunque no suponen un riesgo crítico inmediato, incumplen los estándares actuales de seguridad y exponen a la organización a vulnerabilidades conocidas y documentadas. La calificación A, por el contrario, indica que la configuración cumple simultáneamente todos los requisitos técnicos que SSL Labs verifica, incluyendo versiones de protocolo, cifrados, vulnerabilidades y calidad del certificado (Qualys SSL Labs, 2021). Este salto de B a A no se produce de forma automática con cualquier cambio de configuración: requiere resolver todos los hallazgos identificados en el diagnóstico, lo que valida que el procedimiento de migración diseñado en la metodología es completo y no deja cabos sueltos.

Desde el punto de vista de las versiones de protocolo, el servidor ha pasado de ofrecer tres versiones, de las cuales dos están deprecadas, a ofrecer dos versiones, ambas consideradas seguras por los estándares actuales. Esta reducción no es únicamente una limpieza de configuración: tiene un impacto directo sobre la superficie de ataque del servidor. Cada versión de protocolo habilitada representa un vector de negociación adicional que un atacante en posición de intermediario puede intentar explotar mediante ataques de downgrade para forzar el uso de la versión más débil disponible (Adrian et al., 2015). Al eliminar TLS 1.0 y TLS 1.1, el servidor elimina estos vectores de ataque y obliga a todos los clientes a negociar exclusivamente con TLS 1.2 o TLS 1.3, ambas versiones con mecanismos de protección contra downgrade robustos.

Desde el punto de vista del rendimiento, la activación de TLS 1.3 introduce mejoras cuantificables en el tiempo de establecimiento de conexión. Investigaciones recientes sobre implementaciones reales de TLS 1.3 con OpenSSL en entornos de producción demuestran que la reducción del handshake de 2-RTT a 1-RTT produce una aceleración de aproximadamente un 9% en el tiempo total de establecimiento de la conexión TLS respecto a TLS 1.2, y una mejora de hasta un 44,8% en el tiempo de la capa de intercambio de claves cuando se utilizan mecanismos de encapsulación de clave eficientes (Chen et al., 2025). En el contexto del portal

de cliente de SecureNet Solutions S.L., donde cada sesión de usuario implica múltiples conexiones TLS concurrentes, esta mejora de rendimiento se traduce en una reducción perceptible de la latencia en la carga de páginas, con impacto directo en la experiencia del usuario y potencialmente en el posicionamiento en buscadores, que consideran la velocidad de carga como factor de ranking (Rescorla, 2018).

Desde el punto de vista de los cifrados, el servidor ha pasado de ofrecer una mezcla de suites seguras e inseguras a ofrecer exclusivamente seis suites AEAD con Perfect Forward Secrecy garantizado. Esta homogeneización de la selección de cifrados tiene un efecto que va más allá de la eliminación de suites débiles: garantiza que todas las conexiones TLS establecidas con el servidor, independientemente del cliente que las inicie, utilizan el mismo nivel de protección criptográfica. Con la configuración anterior, un cliente que negociara una suite CBC obtenía un nivel de protección inferior a otro que negociara una suite GCM con el mismo servidor, generando una inconsistencia en la seguridad de las comunicaciones que dependía de factores externos no controlables por el administrador (Bhargavan & Leurent, 2016). La configuración final elimina esta inconsistencia.

Análisis cualitativo

Más allá de las métricas, la comparativa revela un cambio cualitativo en la postura de seguridad de SecureNet Solutions S.L. que tiene implicaciones prácticas para la organización en tres dimensiones.

La primera es la reducción del riesgo operativo. Antes de la migración, el servidor mantenía habilitadas versiones de protocolo cuya explotación está documentada y para las que existen herramientas de ataque públicamente disponibles. Si bien la materialización de un ataque BEAST o POODLE requiere condiciones específicas, la existencia del vector de ataque implica un riesgo residual que la organización asumía sin ser consciente de ello. Tras la migración, ese riesgo residual ha sido eliminado de forma estructural, no mediante mitigaciones parciales sino mediante la deshabilitación completa de los protocolos vulnerables (IETF, 2021; Möller et al., 2014).

La segunda es la mejora de la posición normativa. SecureNet Solutions S.L. puede ahora demostrar de forma objetiva, mediante los informes generados por SSL Labs y testssl.sh, que su servidor web cumple con los requisitos de OWASP ASVS v4.0.2, NIST SP 800-52 e ISO 27001

A.10.1.1. Esta capacidad de demostración objetiva tiene valor práctico en dos escenarios habituales en el contexto empresarial de las PYMEs tecnológicas: cuando un cliente corporativo exige garantías de seguridad como condición para la contratación de servicios, y cuando la organización somete su infraestructura a una auditoría de certificación. En ambos casos, disponer de un informe SSL Labs con calificación A constituye una evidencia inmediata y comprensible para interlocutores tanto técnicos como no técnicos (OWASP, 2019; NIST, 2019; ISO/IEC, 2022).

La tercera es la sostenibilidad de la mejora. La configuración resultante de la migración no es una solución temporal: está alineada con las recomendaciones de los organismos nacionales de ciberseguridad más activos en la materia, incluyendo la guía NCSC holandesa en su edición más reciente de 2025 y las recomendaciones de la ANSSI francesa, cuya vigencia se extiende varios años hacia adelante (NCSC, 2025; ANSSI, 2017). Esto significa que la organización no necesitará revisar su configuración TLS en el corto plazo, salvo que se publiquen nuevas vulnerabilidades en las suites o versiones actualmente habilitadas, lo cual constituiría un evento excepcional y no una eventualidad rutinaria.

Valoración del esfuerzo frente al beneficio

Un elemento diferenciador de la metodología propuesta respecto a otras aproximaciones de auditoría TLS es la proporción entre el esfuerzo requerido y el beneficio obtenido. El procedimiento completo se ha ejecutado sin coste económico adicional, sin interrupciones del servicio y sin necesidad de contratar servicios externos de consultoría. El resultado obtenido es una configuración TLS que cumple con los estándares internacionales de seguridad más exigentes y que puede ser acreditada de forma inmediata mediante herramientas gratuitas ampliamente reconocidas en la industria. Esta proporción esfuerzo-beneficio es precisamente lo que justifica la pertinencia de una metodología ligera orientada a PYMEs, y constituye en sí misma un resultado relevante de la aplicación del caso de uso (Sullivan, 2018; Kotzias et al., 2018).

4.4.4. Discusión de hallazgos

La discusión de los hallazgos tiene como propósito situar los resultados obtenidos en un contexto más amplio, evaluando su significado en relación con los objetivos planteados en el capítulo 3, con las limitaciones inherentes al enfoque adoptado y con las implicaciones que se

derivan de la propuesta metodológica para la comunidad de administradores de sistemas y organizaciones del perfil de SecureNet Solutions S.L.

Validación de los objetivos específicos

El primer objetivo específico planteaba analizar las versiones de TLS habilitadas y los cifrados admitidos en un servidor web mediante herramientas gratuitas de auditoría. Este objetivo queda plenamente validado: SSL Labs y testssl.sh han permitido identificar con precisión las versiones TLS 1.0, 1.1 y 1.2 activas, así como el conjunto completo de cifrados soportados y su orden de preferencia, sin coste económico y sin instalación de software especializado en el servidor auditado. La información obtenida es equivalente en profundidad y fiabilidad a la que proporcionaría una herramienta comercial de auditoría (Qualys SSL Labs, 2021; testssl.sh, 2023).

El segundo objetivo específico planteaba identificar las vulnerabilidades y configuraciones inseguras presentes en una implementación de TLS 1.2. Este objetivo queda igualmente validado: el diagnóstico pre-migración identificó cinco hallazgos concretos clasificados por severidad, de los cuales dos eran de severidad alta por incumplir formalmente el RFC 8996, dos de severidad media por incumplir las recomendaciones de OWASP y los estándares internacionales, y uno de severidad baja por ausencia de HSTS. Esta clasificación por severidad permite priorizar las acciones correctivas de forma racional, lo que constituye un valor añadido metodológico respecto a un simple listado de problemas (IETF, 2021; OWASP, 2019).

El tercer objetivo específico planteaba diseñar una metodología estructurada en cuatro fases para la auditoría y migración a TLS 1.3. La aplicación de las fases de planificación, recogida de información, análisis y diagnóstico, e informe y recomendaciones al caso de SecureNet Solutions S.L. ha demostrado que la estructura en cuatro fases es suficiente para cubrir el ciclo completo de auditoría y migración sin omitir ningún elemento relevante y sin generar complejidad innecesaria. Cada fase produjo los entregables esperados: el documento de alcance en la fase de planificación, los informes de SSL Labs y testssl.sh en la fase de recogida, el diagnóstico con hallazgos clasificados en la fase de análisis, y la configuración final verificada como resultado de la fase de recomendaciones (Rescorla, 2018; Sullivan, 2018).

El cuarto objetivo específico planteaba verificar la mejora en la calificación de seguridad obtenida tras la migración de TLS 1.2 a TLS 1.3. Este es el objetivo más directamente verificable

mediante evidencia objetiva: la calificación ha pasado de B a A en SSL Labs, todas las vulnerabilidades identificadas han sido resueltas, y la configuración final cumple íntegramente con los requisitos de OWASP ASVS v4.0.2, NIST SP 800-52, ISO 27001 A.10.1.1 y las guías NCSC y ANSSI (OWASP, 2019; NIST, 2019; ISO/IEC, 2022; NCSC, 2025; ANSSI, 2017). La mejora es objetiva, medible y reproducible, cumpliendo así el criterio de éxito establecido en el análisis funcional del apartado 4.2.3.

Limitaciones del estudio

La validez de los resultados obtenidos debe interpretarse en el contexto de las limitaciones que el enfoque adoptado conlleva. La primera y más relevante es que el caso de uso se ha aplicado a un entorno simulado con un único servidor web en la nube, auditando exclusivamente el servicio HTTPS en el puerto 443. Una PYME real puede presentar una infraestructura más compleja, con múltiples servicios TLS, servidores en redes internas sin exposición a Internet, aplicaciones heredadas con restricciones de compatibilidad, o dispositivos de red intermedios como balanceadores de carga o proxies inversos que pueden interferir en la negociación TLS. En estos escenarios más complejos, la metodología propuesta sería igualmente aplicable en sus principios, pero requeriría adaptaciones en la selección de herramientas y en la secuencia de pasos, particularmente en la fase de planificación donde la identificación del alcance tendría mayor complejidad (Lee et al., 2017; Kotzias et al., 2018).

La segunda limitación es que la metodología se apoya en herramientas gratuitas cuya disponibilidad y funcionalidades pueden variar con el tiempo. SSL Labs es un servicio externo gestionado por Qualys que puede modificar sus criterios de calificación, sus pruebas de vulnerabilidades o incluso interrumpir su disponibilidad sin previo aviso. testssl.sh es un proyecto de código abierto cuyo mantenimiento depende de su comunidad de desarrolladores. Aunque ambas herramientas llevan años siendo referencias estables en la industria, esta dependencia de servicios y proyectos externos constituye un riesgo a considerar en implementaciones a largo plazo de la metodología (Qualys SSL Labs, 2021; testssl.sh, 2023).

La tercera limitación es inherente al entorno simulado: no ha sido posible verificar el comportamiento de clientes reales con la nueva configuración en condiciones de producción durante un periodo de tiempo prolongado. La verificación funcional básica realizada en el paso 6 del procedimiento de migración confirma que el servicio funciona correctamente tras la

migración, pero no sustituye a un periodo de monitorización en producción que permita detectar problemas de compatibilidad con clientes minoritarios o comportamientos inesperados del servidor bajo carga real.

Implicaciones de la propuesta metodológica

Los resultados obtenidos tienen implicaciones que trascienden el caso concreto de SecureNet Solutions S.L. La demostración de que una PYME tecnológica puede auditar y mejorar su configuración TLS sin coste económico y con herramientas accesibles a cualquier administrador de sistemas, refuta la percepción extendida de que la seguridad TLS avanzada es un dominio exclusivo de organizaciones con recursos especializados. Esta percepción, identificada en el capítulo 1 como una de las principales barreras para la adopción de TLS 1.3 en el tejido empresarial de menor tamaño, queda desacreditada por la evidencia práctica del caso de uso (Kotzias et al., 2018; Lee et al., 2017; Sullivan, 2018).

La metodología propuesta es replicable en cualquier organización que disponga de un servidor web con exposición a Internet, independientemente de su tecnología subyacente, su sistema operativo o su proveedor de infraestructura en la nube. Los principios de las cuatro fases son agnósticos respecto a la tecnología: la fase de planificación identifica el alcance, la fase de recogida ejecuta las herramientas, la fase de análisis interpreta los resultados contra los estándares, y la fase de recomendaciones traduce el diagnóstico en acciones concretas. Esta independencia tecnológica es una característica de diseño deliberada que amplía el alcance potencial de la metodología más allá del escenario específico de Nginx sobre Ubuntu (NCSC, 2025; ANSSI, 2017).

Finalmente, los resultados evidencian que la inversión en seguridad TLS no requiere necesariamente un presupuesto elevado ni personal especializado en ciberseguridad para producir mejoras sustanciales y demostrables. En un contexto en que las PYMEs son objetivos cada vez más frecuentes de ataques cibernéticos precisamente por sus menores defensas, la existencia de metodologías ligeras, documentadas y validadas como la propuesta en este trabajo representa una contribución práctica al objetivo más amplio de elevar el nivel general de seguridad en las comunicaciones corporativas de Internet (Rescorla, 2018; Dowling et al., 2021; Chen et al., 2025).

5. Conclusiones y trabajo futuro

El presente capítulo cierra el trabajo sintetizando los principales hallazgos obtenidos durante el desarrollo de la propuesta y su aplicación al caso de uso. Inicialmente, se exponen las conclusiones del estudio, evaluando el grado de cumplimiento de cada uno de los objetivos específicos formulados en el capítulo 3 e identificando las limitaciones inherentes al enfoque adoptado. Posteriormente, se proponen las líneas de trabajo futuro que permitirían complementar la metodología propuesta, explorar nuevos escenarios de aplicación y extender su uso a otros contextos organizativos y tecnológicos.

5.1. Conclusiones

El presente trabajo ha abordado un problema concreto y documentado en el tejido empresarial de menor tamaño: la ausencia de metodologías ligeras, accesibles y validadas para auditar la configuración TLS de servidores web en entornos de pequeña y mediana empresa. Este problema no es teórico. Las versiones TLS 1.0 y TLS 1.1 siguen activas en numerosos servidores de organizaciones que creen disponer de comunicaciones seguras por el mero hecho de tener un certificado digital. La brecha entre las capacidades del protocolo TLS 1.3 y su implementación real en PYMEs constituye un riesgo evitable que este trabajo ha pretendido contribuir a reducir.

Para abordarlo, se ha diseñado una metodología de auditoría estructurada en cuatro fases secuenciales: planificación, recogida de información, análisis y diagnóstico, e informe y recomendaciones. Cada fase produce entregables concretos y utiliza exclusivamente herramientas gratuitas y ampliamente documentadas. La metodología se ha diseñado con tres criterios fundamentales: simplicidad, para que cualquier administrador de sistemas pueda ejecutarla sin formación especializada en ciberseguridad; reproducibilidad, para que los resultados sean consistentes independientemente de quién realice las pruebas; y bajo costo, para eliminar la barrera económica que impide a muchas PYMEs acceder a auditorías de seguridad profesionales.

La validez de la metodología se ha demostrado mediante su aplicación al caso de uso de SecureNet Solutions S.L., una PYME tecnológica ficticia con un perfil organizativo representativo del tejido empresarial español: 25 empleados, un único administrador de sistemas generalista, infraestructura en la nube y ausencia de personal dedicado a

ciberseguridad. El servidor web de esta organización presentaba una configuración TLS heredada de su instalación inicial, con TLS 1.0 y TLS 1.1 habilitados y cifrados CBC presentes, que producía una calificación B en SSL Labs. Tras la aplicación de la metodología, la calificación pasó a A, los protocolos deprecados fueron eliminados, los cifrados débiles fueron sustituidos por suites AEAD con Perfect Forward Secrecy, y todas las vulnerabilidades identificadas en el diagnóstico fueron resueltas. Todo ello sin coste económico adicional y sin interrupción del servicio.

El primer objetivo específico, analizar las versiones de TLS habilitadas y los cifrados admitidos en un servidor web mediante herramientas gratuitas de auditoría, queda plenamente cumplido. SSL Labs y testssl.sh permitieron identificar con exactitud las versiones activas y el conjunto completo de cifrados soportados, proporcionando información equivalente en profundidad a la que ofrecería una herramienta comercial de auditoría.

El segundo objetivo específico, identificar las vulnerabilidades y configuraciones inseguras presentes en una implementación de TLS 1.2, queda igualmente cumplido. El diagnóstico pre-migración identificó cinco hallazgos concretos clasificados por severidad: dos de severidad alta por incumplimiento formal del RFC 8996, dos de severidad media por incumplimiento de las recomendaciones de OWASP y los estándares internacionales, y uno de severidad baja por ausencia de HSTS.

El tercer objetivo específico, diseñar una metodología estructurada en cuatro fases para la auditoría y migración a TLS 1.3, queda cumplido por el propio desarrollo del trabajo. La aplicación de las cuatro fases al caso de SecureNet Solutions S.L. demostró que la estructura es suficiente para cubrir el ciclo completo de auditoría y migración, que cada fase produce los entregables esperados y que el orden secuencial es coherente y necesario.

El cuarto objetivo específico, verificar la mejora en la calificación de seguridad obtenida tras la migración de TLS 1.2 a TLS 1.3, queda cumplido con evidencia objetiva y directamente verificable. La calificación pasó de B a A en SSL Labs, todas las vulnerabilidades identificadas fueron resueltas, y la configuración final cumple íntegramente con los requisitos de OWASP ASVS v4.0.2, NIST SP 800-52, ISO 27001 A.10.1.1 y las guías de la NCSC holandesa y la ANSSI francesa.

En definitiva, la metodología propuesta es viable, replicable y de bajo costo. Demuestra que una PYME puede auditar y mejorar su postura de seguridad TLS de forma autónoma, sin presupuesto específico y sin personal especializado, alcanzando una configuración alineada con los estándares internacionales más exigentes.

Finalmente, con el objetivo de favorecer la reproducibilidad de la metodología propuesta y facilitar su consulta por parte de estudiantes, investigadores y profesionales, la documentación asociada a este trabajo se ha puesto a disposición pública mediante un repositorio accesible en:

<https://github.com/josevdvega/tfm-metod-tls13-auditoria>.

Esto permitirá consultar, replicar y extender la metodología presentada, contribuyendo a su difusión y a la generación de futuras líneas de investigación y aplicación práctica.

5.2. Limitaciones del estudio

La validez de los resultados obtenidos debe interpretarse en el contexto de las limitaciones que el enfoque adoptado conlleva.

La primera y más relevante es que el caso de uso se ha aplicado a un entorno simulado con un único servidor web en la nube, auditando exclusivamente el servicio HTTPS en el puerto 443. Una PYME real puede presentar una infraestructura más compleja, con múltiples servicios TLS, servidores en redes internas sin exposición a Internet, aplicaciones heredadas con restricciones de compatibilidad, o dispositivos de red intermedios como balanceadores de carga o proxies inversos que pueden interferir en la negociación TLS. En estos escenarios más complejos, la metodología propuesta sería igualmente aplicable en sus principios, pero requeriría adaptaciones en la selección de herramientas y en la secuencia de pasos, particularmente en la fase de planificación donde la identificación del alcance tendría mayor complejidad (Lee et al., 2017; Kotzias et al., 2018).

La segunda limitación es que la metodología se apoya en herramientas gratuitas cuya disponibilidad y funcionalidades pueden variar con el tiempo. SSL Labs es un servicio externo gestionado por Qualys que puede modificar sus criterios de calificación, sus pruebas de vulnerabilidades o incluso interrumpir su disponibilidad sin previo aviso. testssl.sh es un proyecto de código abierto cuyo mantenimiento depende de su comunidad de desarrolladores. Aunque ambas herramientas llevan años siendo referencias estables en la

industria, esta dependencia de servicios y proyectos externos constituye un riesgo a considerar en implementaciones a largo plazo de la metodología (Qualys SSL Labs, 2021; testssl.sh, 2023).

La tercera limitación es inherente al entorno simulado: no ha sido posible verificar el comportamiento de clientes reales con la nueva configuración en condiciones de producción durante un periodo de tiempo prolongado. La verificación funcional básica realizada en el paso 6 del procedimiento de migración confirma que el servicio funciona correctamente tras la migración, pero no sustituye a un periodo de monitorización en producción que permita detectar problemas de compatibilidad con clientes minoritarios o comportamientos inesperados del servidor bajo carga real.

En este sentido, aunque la validación se ha realizado sobre una empresa ficticia, el escenario fue diseñado para reproducir las características habituales de PYMEs, permitiendo evaluar la metodología en un contexto representativo y controlado. Con esta aproximación ha facilitado la documentación completa del proceso y obtención de evidencias reproducibles, si bien futuras validaciones en entornos reales permitirían contrastar los resultados obtenidos en escenarios en producción.

5.3. Trabajos futuros

El trabajo desarrollado abre varias líneas de investigación y desarrollo orientadas a complementar la metodología propuesta, explorar nuevos escenarios de aplicación y extender su uso a otros contextos organizativos y tecnológicos.

5.3.1 Extensión a otros servicios TLS

La metodología propuesta se ha diseñado y validado exclusivamente para auditar servicios HTTPS en servidores web. Sin embargo, el protocolo TLS protege una variedad mucho más amplia de comunicaciones corporativas: servidores de correo electrónico con STARTTLS, servidores de transferencia de ficheros con FTPS, servicios de mensajería, APIs internas y conexiones de bases de datos. Cada uno de estos servicios presenta particularidades en su configuración TLS que la metodología actual no cubre.

Una línea de trabajo futuro de alto valor práctico consistiría en extender la metodología para incluir estos servicios, definiendo para cada uno los pasos específicos de la fase de recogida de información, las herramientas adecuadas cuando SSL Labs no es aplicable por tratarse de

servicios no web, y los criterios de evaluación correspondientes. Esta extensión aumentaría significativamente la cobertura de la metodología y su utilidad real para organizaciones con infraestructuras más diversificadas, permitiendo cubrir el ciclo completo de comunicaciones cifradas de una PYME en una única auditoría estructurada.

5.3.2 Aplicación en entornos de producción reales

Una de las limitaciones identificadas en este trabajo es que el caso de uso se aplicó a un entorno simulado. La aplicación de la metodología a organizaciones reales con servidores en producción permitiría validar su efectividad en condiciones más complejas y variables: parques de clientes heterogéneos con navegadores y sistemas operativos de distintas generaciones, dispositivos intermedios como proxies inversos o balanceadores de carga que pueden interferir en la negociación TLS, y aplicaciones heredadas con restricciones de compatibilidad no documentadas.

Un estudio longitudinal que siguiera la evolución de la configuración TLS de una muestra de PYMEs antes y después de aplicar la metodología, con mediciones periódicas a los seis y doce meses, aportaría evidencia empírica sobre la sostenibilidad de las mejoras y la necesidad de revisiones periódicas. Este tipo de estudio requeriría la colaboración de organizaciones reales y la aplicación de un protocolo de investigación estructurado, pero produciría resultados de alto valor para la comunidad académica y profesional de la ciberseguridad.

5.3.3 Automatización del proceso de auditoría

La metodología propuesta es manual en su ejecución: el administrador ejecuta las herramientas, interpreta los resultados y aplica las correcciones. Esta aproximación es adecuada para organizaciones sin recursos técnicos especializados, pero limita la escalabilidad de la metodología en organizaciones con múltiples servidores o que deseen integrar la auditoría TLS en sus procesos de desarrollo y despliegue.

Una línea de trabajo futuro consistiría en desarrollar un conjunto de scripts que automaticen las fases de recogida de información y análisis, ejecutando `testssl.sh` sobre una lista predefinida de servidores, procesando la salida para identificar automáticamente los hallazgos clasificados por severidad y generando un informe estructurado sin intervención manual. Esta automatización podría integrarse en pipelines de integración continua y despliegue continuo (CI/CD), permitiendo que la auditoría TLS se ejecute automáticamente con cada despliegue de

infraestructura y alertando al equipo técnico ante cualquier regresión en la configuración de seguridad. La herramienta testssl.sh ya soporta salida en formato JSON que facilitaría este procesamiento automatizado.

5.3.4 Adaptación a tecnologías alternativas y entornos cloud

El caso de uso de este trabajo se implementó sobre Nginx en Ubuntu Server 22.04 LTS. Si bien los principios de la metodología son agnósticos respecto a la tecnología, los pasos concretos del procedimiento de migración están documentados para este stack específico. Una línea de trabajo futuro de alto valor práctico consistiría en desarrollar variantes del procedimiento de migración para otras tecnologías de servidor ampliamente utilizadas: Apache HTTP Server, Microsoft IIS, y servicios gestionados en plataformas cloud como AWS CloudFront, Azure Application Gateway o Google Cloud Load Balancing.

En estos últimos casos, la configuración TLS no se gestiona mediante archivos de texto en el servidor sino a través de interfaces de administración de la nube, lo que implica procedimientos de migración completamente diferentes. Documentar estos procedimientos dentro del marco de la metodología propuesta ampliaría significativamente su aplicabilidad y eliminaría una barrera importante para organizaciones que operan infraestructura cloud nativa, que representa una proporción creciente del tejido empresarial tecnológico actual.

5.3.5 Validación por panel de expertos

Este trabajo ha validado la metodología mediante su aplicación a un caso de uso concreto. Una línea de trabajo futuro valiosa consistiría en complementar esta validación práctica con una validación por panel de expertos: un grupo de profesionales con experiencia en auditorías de seguridad, administración de sistemas y ciberseguridad corporativa que evaluarán la metodología mediante un cuestionario estructurado, valorando dimensiones como su completitud, su claridad, su aplicabilidad práctica y su alineación con los estándares del sector.

Los resultados de esta evaluación por expertos aportarían una perspectiva externa independiente que reforzaría la validez de la metodología y podría identificar aspectos de mejora no detectados durante la aplicación al caso de uso simulado. Este enfoque es coherente con las recomendaciones académicas para la evaluación de metodologías en trabajos de fin de máster, que señalan la consulta a expertos como una de las vías de validación más robustas disponibles.

Finalmente, con el objetivo de favorecer la consulta, replicación y extensión de la metodología propuesta por parte de investigadores, estudiantes y profesionales, toda la documentación asociada a este trabajo se encuentra disponible en el siguiente repositorio público: <https://github.com/josevdvega/tfm-metod-tls13-auditoria>. Este recurso permite acceder a los materiales desarrollados, facilita la reproducibilidad del trabajo y constituye una base sobre la que construir las líneas de investigación aquí propuestas.

Referencias bibliográficas

- Adrian, D., Bhargavan, K., Durumeric, Z., Gaudry, P., Green, M., Halderman, J. A., Heninger, N., Springall, D., Thomé, E., Valenta, L., et al. (2015). Imperfect forward secrecy: How Diffie-Hellman fails in practice. *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*, 5-17.
- AlFardan, N. J., & Paterson, K. G. (2013). Lucky Thirteen: Breaking the TLS and DTLS record protocols. *Proceedings of the 2013 IEEE Symposium on Security and Privacy*, 526-540.
- ANSSI. (2017). *Security recommendations for TLS (Version 1.1, EN)*. Agence Nationale de la Sécurité des Systèmes d'Information. <https://www.ssi.gouv.fr/guide/security-recommendations-for-tls/>
- Aviram, N., Schinzel, S., Somorovsky, J., Heninger, N., Dankel, M., Steube, J., Valenta, L., Adrian, D., Halderman, J. A., Dukhovni, V., et al. (2016). *DROWN: Decrypting RSA with Obsolete and Weakened eNcryption*. <https://drownattack.com/>
- Azás, D. (2018). *Attacks on SSL/TLS* [Graduate thesis]. Aristotle University of Thessaloniki.
- Bard, G. V. (2006). *The vulnerability of SSL to chosen plaintext attack*. Cryptology ePrint Archive, Report 2006/232.
- Be'ery, T., & Shulman, A. (2013). A perfect CRIME? Only TIME will tell. *BlackHat Europe 2013*. IMPERVA.
- Beurdouche, B., Bhargavan, K., Delignat-Lavaud, A., Fournet, C., Kohlweiss, M., Pironi, A., Strub, P. Y., & Zinzindohoue, J. K. (2015). A messy state of the union: Taming the composite state machines of TLS. *Proceedings of the IEEE Symposium on Security and Privacy*, 535-552.
- Bhargavan, K., & Leurent, G. (2016). On the practical (in-)security of 64-bit block ciphers: Collision attacks on HTTP over TLS and OpenVPN. *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 456-467.
- Chen, J., Peng, W., Wang, Y., & Bian, Y. (2025). On the security and efficiency of TLS 1.3 handshake with hybrid key exchange from CPA-secure KEMs. *Entropy*, 27(12), 1242. <https://doi.org/10.3390/e27121242>

- Cloudflare. (2018). *Introducing Zero Round Trip Time Resumption (0-RTT)*.
<https://blog.cloudflare.com/introducing-0-rtt/>
- Dierks, T., & Allen, C. (1999). *The TLS Protocol Version 1.0 (RFC 2246)*. Internet Engineering Task Force.
- Dierks, T., & Rescorla, E. (2008). *The Transport Layer Security (TLS) Protocol Version 1.2 (RFC 5246)*. Internet Engineering Task Force.
- Diffie, W., & Hellman, M. E. (1976). New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6), 644-654.
- Dowling, B., Fischlin, M., Günther, F., & Stebila, D. (2021). A cryptographic analysis of the TLS 1.3 handshake protocol. *Journal of Cryptology*, 34(4), 1-69.
- Duong, T., & Rizzo, J. (2011). *Here come the XOR Ninjas*. Presentation at Ekoparty Security Conference.
- Durumeric, Z., Kasten, J., Adrian, D., Halderman, J. A., Bailey, M., Li, F., Weaver, N., Amann, J., Beekman, J., Payer, M., et al. (2014). The matter of Heartbleed. *Proceedings of the Conference on Internet Measurement Conference*, 475-488.
- Durumeric, Z., Wustrow, E., & Halderman, J. A. (2013). ZMap: Fast internet-wide scanning and its security applications. *Proceedings of the 22nd USENIX Security Symposium*, 605-620.
- ENISA. (2021). *Recommendations for TLS/SSL usage*. European Union Agency for Cybersecurity.
- Felt, A. P., Barnes, R., King, A., Palmer, C., Bentzel, C., & Tabriz, P. (2017). Measuring HTTPS adoption on the web. *Proceedings of the 26th USENIX Security Symposium*, 1323-1338.
- Freier, A., Karlton, P., & Kocher, P. (1996). *The SSL Protocol Version 3.0*. Netscape Communications.
- IETF. (1999). *The TLS Protocol Version 1.0 (RFC 2246)*. Internet Engineering Task Force.
- IETF. (2006). *The Transport Layer Security (TLS) Protocol Version 1.1 (RFC 4346)*. Internet Engineering Task Force.
- IETF. (2008). *The Transport Layer Security (TLS) Protocol Version 1.2 (RFC 5246)*. Internet Engineering Task Force.

- IETF. (2021). *Deprecating TLS 1.0 and TLS 1.1 (RFC 8996)*. Internet Engineering Task Force.
- INE. (2023). *Directorio Central de Empresas (DIRCE): Resultados estadísticos 2023*. Instituto Nacional de Estadística. <https://www.ine.es>
- ISO/IEC. (2022). *Information technology — Security techniques — Information security management systems — Requirements (ISO/IEC 27001:2022)*. International Organization for Standardization.
- Kotzias, P., Razaghpanah, A., Amann, J., Paterson, K. G., Springall, D., & Vallina-Rodriguez, N. (2018). Coming of age: A longitudinal study of TLS deployment. *Proceedings of the ACM Internet Measurement Conference (IMC)*, 415-428.
- Langley, A., Modadugu, N., & Moeller, B. (2016). *Transport Layer Security (TLS) False Start*. IETF Draft.
- Lee, S., Kim, J., & Huh, J. H. (2017). Empirical analysis of SSL/TLS weaknesses in real websites: Who cares? *Lecture Notes in Computer Science*, 10144, 174-185.
- Lyon, G. F. (2009). *Nmap network scanning: The official Nmap project guide to network discovery and security scanning*. Insecure.
- Möller, B., Duong, T., & Kotowicz, K. (2014). *This POODLE bites: Exploiting the SSL 3.0 fallback*. Google.
- NCSC. (2025). *Transport Layer Security (TLS): Security guidelines version 2025-05*. National Cyber Security Centre of the Netherlands.
- NIST. (2019). *Guidelines for the selection and configuration of Transport Layer Security (TLS) implementations (SP 800-52r2)*. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-52r2>
- OpenSSL Project. (2014). *OpenSSL Cryptographic Library*. <https://www.openssl.org/>
- OWASP. (2019). *OWASP Application Security Verification Standard (ASVS Version 4.0.2)*. Open Web Application Security Project.
- OWASP. (2023). *ASVS Version 5.0: V12 Secure Communication*. Open Web Application Security Project.

- Paulson, L. C. (1999). Inductive analysis of the internet protocol TLS. *ACM Transactions on Information and System Security*, 2(3), 332-351.
- Polk, W. T., Hastings, R. A., & Dodson, D. F. (2016). *Cryptographic algorithm validation program* (NIST Interagency Report 7977). National Institute of Standards and Technology.
- Qualys SSL Labs. (2021). *SSL Server Test documentation*. Qualys, Inc.
- Rescorla, E. (2001). *SSL and TLS: Designing and building secure systems*. Addison-Wesley.
- Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3 (RFC 8446)*. Internet Engineering Task Force. <https://doi.org/10.17487/RFC8446>
- Rizzo, J., & Duong, T. (2012). *The CRIME attack*. Presentation at Ekoparty Security Conference.
- Sheffer, Y., Holz, R., & Saint-Andre, P. (2015). *Recommendations for secure use of Transport Layer Security (TLS) and Datagram Transport Layer Security (DTLS) (RFC 7525)*. Internet Engineering Task Force.
- Snapshot. (s.f.). *TLS 1.3 overview and Q&A*. Cloudflare Blog.
- Sullivan, N. (2018). *TLS 1.3: One year later*. Cloudflare Blog.
- Tecnologías habilitadoras. (s.f.). *Adoption of TLS 1.3*. Internet Society Pulse.
- testssl.sh. (2023). *testssl.sh: Testing TLS/SSL encryption anywhere*. <https://testssl.sh/>
- Wagner, D., & Schneier, B. (1996). Analysis of the SSL 3.0 protocol. *Proceedings of the 2nd USENIX Workshop on Electronic Commerce*, 29-40.